

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG



PHẠM HOÀNG DUY

BÀI GIẢNG

AN TOÀN HỆ ĐIỀU HÀNH

HÀ NỘI 2017

Lời nói đầu

Hệ điều hành là một bộ phận cấu thành quan trọng của hệ thống máy tính giúp cho con người có thể khai thác và sử dụng hiệu quả hệ thống máy tính. Sự phổ biến của máy tính và sự phát triển các ứng dụng mạng khiến cho vấn đề về an toàn trở nên cấp thiết. Bài giảng môn học trước hết giới thiệu các yêu cầu và các kiến trúc cơ bản đáp ứng mục tiêu an toàn cho hệ điều hành. Đồng thời, bài giảng trình bày một số cơ chế phần cứng máy tính cho phép hạn chế, che giấu, và kiểm soát việc sử dụng các tài nguyên máy tính như bộ xử lý, bộ nhớ và các thiết bị vào/ra để hỗ trợ cho hệ điều hành có thể triển khai các dịch vụ cơ bản như quản lý tiến trình một cách an toàn. Ngoài ra, bài giảng giới thiệu các mô hình an toàn chính tắc phục vụ cho các yêu cầu an toàn khác nhau của hệ thống như tính toàn vẹn hay tính bí mật. Phần cuối cùng trình bày cách thức mô tả các yêu cầu cũng như kỹ thuật kiểm chứng nhằm kiểm tra và đánh giá khả năng đáp ứng yêu cầu an toàn của hệ thống.

Cấu trúc chi tiết bài giảng như sau.

Chương I giới thiệu vấn đề cơ bản với an toàn hệ điều hành tập trung chủ yếu vào việc mô tả và xác định các mục tiêu cũng như yêu cầu an toàn với hệ điều hành nói chung. Việc xây dựng chính sách mô tả chính xác và xác định mục tiêu an toàn phù hợp đóng vai trò then chốt trong việc phát triển các cơ chế bảo vệ đảm bảo an toàn cho hệ điều hành cũng như việc đánh giá tính an toàn của các cơ chế này với hệ thống. Nhân an toàn và nền tảng tính toán tin cậy là bộ phận quan trọng và then chốt trong việc kiểm soát và đảm bảo an toàn cho các chương trình người dùng cũng như bản thân hệ điều hành.

Chương II trình bày một số cơ chế đảm bảo an toàn phần cứng dựa trên cơ chế bảo vệ theo lớp. Trong đó mỗi lớp được gán với một mức đặc quyền cho phép tiến trình của người dùng được phép truy nhập tới những thao tác nhất định. Cơ chế này đóng vai trò cốt lõi cho kiểm soát việc thực thi, sử dụng bộ nhớ của các tiến trình cũng như là truy nhập tới các thiết bị vào/ra.

Chương III tập trung vào cơ chế an toàn của kiến trúc x86 đối với các dịch vụ cơ bản của hệ điều hành như quản lý việc thực thi của các chương trình cũng như quản lý bộ nhớ. Các yêu cầu về tính toàn vẹn và bí mật của hệ thống file nhận được sự hỗ trợ và đảm bảo tốt hơn so với việc mã hóa thông thường từ mô-đun hạ tầng tin cậy TPM nhờ vào việc bảo vệ khóa và xác thực được đóng gói bằng phần cứng. Phần cuối chương giới thiệu cách thức triển khai cơ chế bảo đảm an toàn trong hệ điều hành sử dụng kiến trúc x86 đó là Windows và Unix/Linux. Các vấn đề an toàn với các hệ điều hành được thảo luận chi tiết trong phần này. Ngoài ra, phần này cũng giới thiệu một số cách tiếp cận nhằm đảm bảo các yêu cầu an toàn và kiểm chứng ở mức độ cao các yêu cầu này bao gồm nhân an toàn SCOMP và các mô-đun an toàn Linux.

Chương IV trình bày các mô hình an toàn chính tắc cho phép mô tả và kiểm chứng các yêu cầu cần phải đạt với mô hình đề xuất. Ngoài mô hình truyền thống dựa trên máy

trạng thái, chương này giới thiệu các mô hình cho phép đảm bảo các yêu cầu về tính toàn vẹn và bí mật của hệ thống máy tính. Phần này chỉ trình bày các kết quả thu được và bỏ qua các chi tiết chứng minh các kết quả này.

Chương V giới thiệu cách thức giúp cho việc đánh giá và kiểm tra các yêu cầu an toàn với hệ thống máy tính thông qua việc xây dựng các đặc tả yêu cầu hệ thống. Ngoài ra, phần này giới thiệu hai kỹ thuật kiểm chứng mã chương trình có đảm bảo yêu cầu đặt ra hay không. Đó là phương pháp phân tích tĩnh và phân tích động. Về cơ bản, phần đầu chương cho phép đánh giá tính an toàn của hệ thống xét về mặt thiết kế. Phần phân tích mã chương trình nhằm kiểm tra và đánh giá việc triển khai cũng như các hành vi của chương trình.

PTIT

Mục lục

CHƯƠNG 1. TỔNG QUAN AN TOÀN HỆ ĐIỀU HÀNH.....	8
1.1 Giới thiệu.....	8
1.2 Các vấn đề về kiến trúc an toàn.....	15
1.3 Chính sách an toàn	17
1.4 Nền tảng tính toán tin cậy.....	18
1.5 Nhân an toàn.....	23
1.6 Câu hỏi ôn tập.....	26
CHƯƠNG 2. CÁC CƠ CHẾ AN TOÀN PHẦN CỨNG	27
2.1 Hỗ trợ các tiến trình.....	27
2.2 Bảo vệ bộ nhớ.....	29
2.3 Kiểm soát thao tác vào/ra	31
2.4 Ảo hóa	33
2.5 Kết luận	34
2.6 Câu hỏi ôn tập.....	35
CHƯƠNG 3. AN TOÀN CÁC DỊCH VỤ CƠ BẢN CỦA HỆ ĐIỀU HÀNH	36
3.1 Quản lý tiến trình.....	36
3.2 Quản lý bộ nhớ	38
3.3 Hệ thống file.....	42
3.4 Phân tích an toàn các dịch vụ cơ bản hệ điều hành Windows và Unix/Linux.....	48
3.5 Kết luận	65
3.6 Câu hỏi ôn tập.....	66
CHƯƠNG 4. CÁC MÔ HÌNH AN TOÀN	67
4.1 Vai trò và đặc trưng của mô hình an toàn.....	67
4.2 Mô hình máy trạng thái	69
4.3 Mô hình Harrison-Ruzzo-Ullman.....	72
4.4 Các mô hình khác	74
4.5 Kết luận	79
4.6 Câu hỏi ôn tập.....	79
CHƯƠNG 5. ĐÁNH GIÁ AN TOÀN	80
5.1 Các đặc trưng của đặc tả an toàn	80
5.2 Các kỹ thuật kiểm chứng đặc tả an toàn.....	82
5.3 Các phương pháp phân rã dữ liệu và chương trình	88
5.4 Các kỹ thuật kiểm chứng mã chương trình	91
5.5 Kết luận	99
5.6 Câu hỏi ôn tập.....	99

Danh mục các hình vẽ

Hình 1-1. Hệ điều hành điều phối truy nhập của các tiến trình	8
Hình 1-2. Ma trận truy nhập với hai tiến trình.....	12
Hình 1-3. Hệ thống bảo vệ bắt buộc	14
Hình 1-4. Mô đun TPM phần cứng.....	20
Hình 1-5. Các bộ phận chức năng của TPM	22
Hình 1-6. Tương tác giữa tiến trình và bộ giám sát tham chiếu	25
Hình 2-1. Các lớp bảo vệ tiêu biểu	28
Hình 2-2. Cấu trúc mô tả phần nhớ cổng.....	29
Hình 2-3. Xung đột bộ nhớ chương trình người dùng.....	30
Hình 2-4. Ánh xạ từ bộ nhớ ảo tới bộ nhớ vật lý.....	30
Hình 2-5. Mô tả các chế độ truy nhập bộ nhớ của User và System.....	31
Hình 2-6. Ánh xạ thiết bị ảo tới thiết bị vật lý	32
Hình 3-1. Thẻ <u>chọn đoạn</u> dữ liệu và lệnh.....	37
Hình 3-2. Kiểm tra <u>mức đặc quyền</u> của <u>đoạn lệnh</u>	38
Hình 3-3. Thẻ mô tả đoạn	39
Hình 3-4. Thẻ chọn đoạn.....	39
Hình 3-5. Truy nhập bộ nhớ qua GDT.....	40
Hình 3-6. Cấu trúc không gian nhớ của tiến trình và thông tin quản lý bộ nhớ	41
Hình 3-7. Kiểm tra đặc quyền truy nhập bộ nhớ	41
Hình 3-8. Tính toán cơ sở tin cậy trong quá trình khởi động	43
Hình 3-9. Khởi động được bảo vệ trong Windows với BIOS truyền thống.....	45
Hình 3-10. Bảo vệ và sử dụng <u>khóa mã</u> bằng TPM.....	47
Hình 3-11. Quá trình giải mã ổ đĩa BitLocker	47
Hình 3-12. Danh sách kiểm soát truy nhập và thẻ của các tiến trình.....	50
Hình 3-13. Cơ chế bảo vệ bằng bit chế độ.....	54
Hình 3-14. Kiến trúc giao tiếp LSM	59
Hình 3-15. Kiến trúc SCOMP.....	62
Hình 3-16. Phần cứng của SCOMP	63
Hình 4-1. Tương quan giữa các bước phát triển mô hình an toàn	68
Hình 4-2. Xây dựng luồng thông tin	75
Hình 4-3. Nguyên tắc an toàn trong Bell-La Padula.....	76
Hình 5-1. Giao tiếp giữa hai hệ thống.....	81

Hình 5-2. Tương quan giữa mô hình và đặc tả an toàn	82
Hình 5-3. Quan hệ giữa các đối tượng trong hệ thống file	86
Hình 5-4. Phản chứng cho thấy lỗi với thư mục tuần hoàn	88
Hình 5-5. Các mức độ chi tiết của việc đặc tả giữa mô hình và việc triển khai	89
Hình 5-6. Phân rã thuật toán theo các lớp.....	90
Hình 5-7. Phân rã thuật toán cho thao tác hệ thống file.....	91
Hình 5-8. Mô hình phân tích tĩnh đoạn mã	92
Hình 5-9. Bộ luật <u>sinh cây</u> phân tích.....	93
Hình 5-10. Cây cú pháp của câu lệnh	94
Hình 5-11. Cây cú pháp khái quát	94
Hình 5-12. Luồng điều khiển	95
Hình 5-13. Đồ thị gọi hàm của ba phương thức <u>larry</u> , <u>moe</u> , <u>curly</u>	95
Hình 5-14. Các công cụ phân tích tĩnh	96

PTIT

Các từ viết tắt

ACL – Access Control List: Danh sách kiểm soát truy nhập

BIOS – Basic Input Output System: Hệ thống vào ra cơ bản

CPU – Central Processing Unit: Đơn vị xử lý trung tâm

DAC – Discretionary Access Control: Kiểm soát truy nhập tùy chọn

DEP – Data Execution Prevention: Ngăn chặn thực thi dữ liệu

EAL - Evaluation Assurance Levels: Mức độ đánh giá an toàn

FAT– File Allocation Table: Bảng cấp phát file

GUI – Graphic User Interface: Giao diện người dùng đồ họa

IDE – Integrated Development Environment: Môi trường phát triển tích hợp

IDS – Intrusion Detection System: Hệ thống phát hiện xâm nhập

LSM – Linux Security Module: Mô-đun an ninh Linux

MAC – Mandatory Access Control: Kiểm soát truy nhập bắt buộc

MLS – Multi-Level Security: An toàn nhiều mức

NX – No eXecution: Cấm thực thi

OS – Operating System: Hệ điều hành

PC – Personal Computer: máy tính cá nhân

PCR – Platform Configuration Register: Thanh ghi cấu hình hệ thống

POSIX – Portable Operating System Interface: Giao tiếp hệ điều hành khả chuyển

RBAC – Role Based Access Control: Kiểm soát truy nhập theo vai trò

SCOMP – Secure Communication Processor: Bộ xử lý truyền thông an toàn

SELinux – Secure-Enhanced Linux: Linux với an ninh tăng cường.

TPM – Trusted Platform Module: Mô-đun hạ tầng tin cậy

UEFI – Unified Extensible Firmware Interface: Giao tiếp firmware mở rộng hợp nhất

UML – Unified Modeling Language: Ngôn ngữ lập mô hình hợp nhất

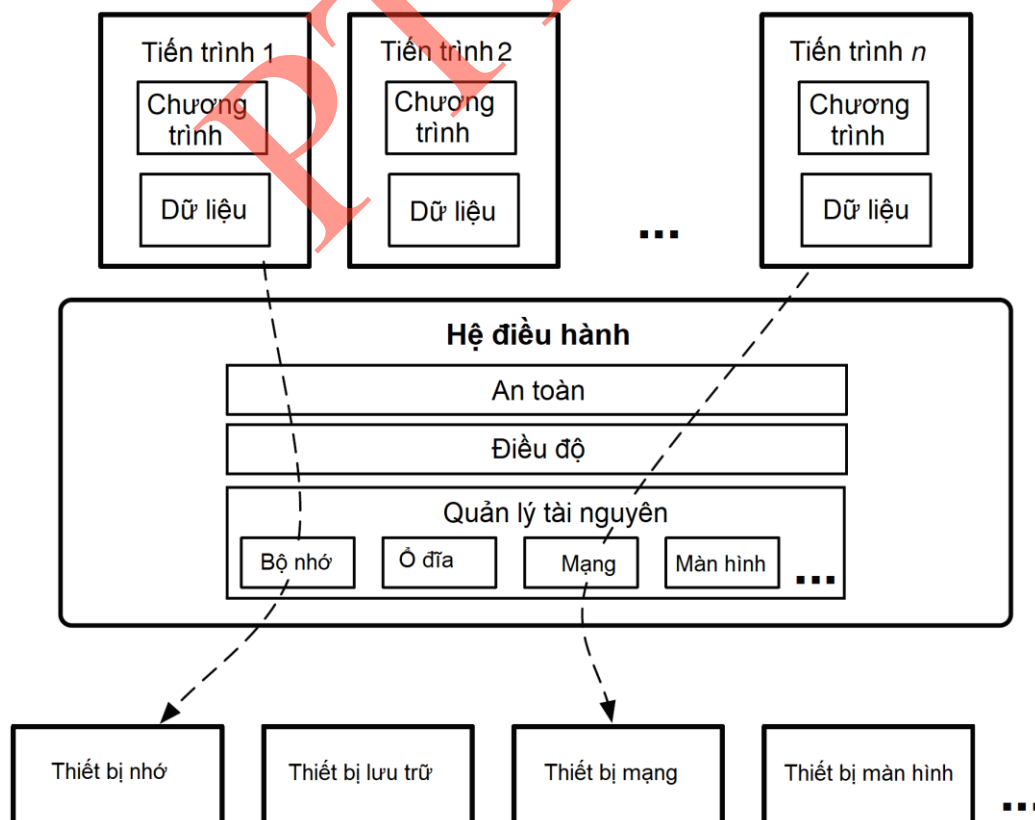
CHƯƠNG 1. TỔNG QUAN AN TOÀN HỆ ĐIỀU HÀNH

Hệ điều hành là phần mềm đặc biệt cho phép người dùng truy nhập tới các tài nguyên phần cứng khác nhau mà chúng cấu thành hệ thống máy tính cụ thể bao gồm bộ xử lý, bộ nhớ, các thiết bị ngoại vi. Bất kỳ phần mềm nào chạy trên hệ thống máy tính đều sử dụng tập lệnh được cung cấp bởi bộ xử lý của hệ thống đó và phần mềm này cũng có thể cần dùng các tài nguyên khác như truy nhập tới ổ cứng hay mạng. Người dùng thông qua các chương trình để sử dụng phần cứng máy tính như kết nối mạng, xử lý dữ liệu hay giải trí.

Một cách khái quát, vấn đề an toàn hệ điều hành liên quan đến an toàn trong việc chia sẻ hay phân chia các tài nguyên mà các phần mềm sử dụng trong quá trình hoạt động của chúng.

1.1 Giới thiệu

Hệ điều hành hiện đại cần cho phép chạy nhiều chương trình hay người dùng, ở dạng các tiến trình (process), cùng đồng thời chia sẻ sử dụng các tài nguyên của hệ thống (như trong hình dưới đây). Như vậy, hệ điều hành phải đảm bảo ba chức năng căn bản như sau:



Hình 1-1. Hệ điều hành điều phối truy nhập của các tiến trình

- Hệ điều hành phải cung cấp cơ chế sử dụng tài nguyên hiệu quả. Nói cách khác, hệ điều hành cần xác định rõ cách thức cách tiến trình sử dụng tài nguyên phần cứng và ngăn chặn các xung đột khi sử dụng tài nguyên. Các chức năng tiêu biểu gồm có: quản lý CPU, quản lý bộ nhớ, quản lý hệ thống file, giao thức mạng, ...;
- Hệ điều hành phải cung cấp cơ chế điều độ giữa các chương trình người dùng đảm bảo việc sử dụng tài nguyên công bằng;
- Hệ điều hành phải kiểm soát việc truy nhập tới các tài nguyên sao cho chương trình người dùng không ảnh hưởng một cách vô tình hay xấu tới chương trình khác. Đây chính là vấn đề đảm bảo an toàn cho các chương trình chạy trong hệ thống.

Việc đảm bảo các chương trình hoạt động một cách an toàn lệ thuộc vào việc triển khai đúng đắn các cơ chế chia sẻ và điều độ tài nguyên như sau:

- Các cơ chế truy nhập tài nguyên phải xác định ranh giới các tài nguyên và đảm bảo các thao tác tới các tài nguyên này không xung đột với nhau.
- Cơ chế điều độ phải đảm bảo tính sẵn sàng của tài nguyên cho các chương trình để ngăn chặn việc từ chối dịch vụ.

Một cách lý tưởng các cơ chế này đảm bảo các chương trình hoạt động bình thường và không gian nhớ không bị tổn thất cho dù việc xâm phạm các nguyên tắc chia sẻ hay phối hợp xảy ra một cách có chủ ý.

Vấn đề an toàn ngày càng được quan tâm do các chương trình trong máy tính hiện đại tương tác với nhau theo nhiều cách và việc chia sẻ dữ liệu giữa các người dùng là hành vi căn bản và phổ biến với hệ thống máy tính được nối mạng và gắn kết chặt chẽ. Thách thức với việc thiết kế an toàn cho hệ điều hành là thiết kế các cơ chế an toàn để bảo vệ việc thực thi của các chương trình và dữ liệu của chúng trong môi trường phức tạp. Các cơ chế an toàn chính tắc (*formal security mechanism*) giúp chứng minh về mặt toán học hệ thống đạt được các mục tiêu an toàn song không tính đến độ phức tạp của hệ thống. Trong nhiều tình huống, độ phức tạp khiến cho việc chứng minh lý thuyết là không khả thi.

Trên thực tế, an toàn hệ điều hành được tiếp cận theo hai hướng chủ yếu. Một là hệ thống hạn chế (*constrained*): đảm bảo các mục tiêu an toàn được thỏa mãn với mức độ cao. Hai là hệ thống dùng chung (*general-purpose*): chỉ đảm bảo các mục tiêu an toàn một cách giới hạn với mức độ thấp. Các hệ thống hạn chế hỗ trợ ít ứng dụng cũng như chức năng song đảm bảo mục tiêu chủ yếu là tính an toàn. Việc hạn chế các chức năng cho phép hệ thống có thể kiểm chứng được tính đúng đắn của các mục tiêu an toàn đề ra. Mặt khác, các hệ thống dùng chung hướng tới cung cấp các chức năng mềm dẻo, thân thiện người dùng, dễ triển khai và có hiệu năng cao. Các đặc điểm này dẫn đến nhiều thách thức với việc đảm bảo an toàn cho hệ thống.

Hệ điều hành an toàn, một cách lý tưởng, là hệ điều hành cung cấp cơ chế bảo vệ đảm bảo đạt được các mục tiêu an toàn của hệ thống cho dù hệ thống phải đối mặt với

các mối đe dọa. Các cơ chế an toàn này được thiết kế trong ngữ cảnh của việc chia sẻ và điều độ tài nguyên. Các mục tiêu an toàn của hệ thống phải được duy trì bất kể cách thức sử dụng hệ thống (như bị tấn công bởi người bẻ khóa).

Thông thường hệ điều hành đạt được mức độ đảm bảo cao được coi là hệ điều hành an toàn hay gọi là hệ thống tin cậy (*trusted system*). Thực tế, không có hệ thống hiện đại phức tạp nào hoàn toàn an toàn. Những khó khăn của việc ngăn ngừa các lỗi lập trình và các thách thức để loại bỏ những lỗi như vậy dẫn đến không hệ thống nào phức tạp như hệ điều hành có thể hoàn toàn an toàn. Dù vậy, việc xây dựng hệ điều hành an toàn vẫn rất cần thiết và giúp cho người dùng có thể xác định hay đánh giá được mức độ an toàn của hệ thống họ sử dụng hay theo đuổi.

Các yếu tố giúp xây dựng hệ điều hành an toàn bao gồm mục tiêu an toàn, các mô hình đe dọa và tin cậy, và cơ chế bảo vệ.

a. **Mục tiêu an toàn**

Mục tiêu an toàn (*security goal*) xác định các thao tác có thể được thực hiện bởi hệ thống trong khi ngăn chặn các truy nhập trái phép. Các mục tiêu này cần được định nghĩa ở mức độ khái quát cao. Các mục tiêu an toàn xác định các yêu cầu mà thiết kế hệ thống cần phải thỏa mãn và việc triển khai đúng đắn phải đáp ứng đầy đủ các yêu cầu này.

Mục tiêu an toàn mô tả các truy nhập tới các tài nguyên của hệ thống mà chúng cần thỏa mãn các yếu tố sau: bí mật, toàn vẹn, và sẵn dùng. Truy nhập hệ thống được mô tả bằng *chủ thể* (chương trình hay người dùng) có thể thực hiện *các thao tác* (đọc hay ghi) lên các *đối tượng* (file hay socket). Như vậy, các thuộc tính an toàn nêu trên được hiểu như sau:

- Tính bí mật giới hạn các đối tượng có thể được truy nhập
- Tính toàn vẹn hạn chế các đối tượng mà chủ thể có thể ghi để đảm bảo thao tác được đúng đắn trong quan hệ với các thao tác của các chủ thể khác
- Tính sẵn dùng hạn chế các tài nguyên mà các chủ thể có thể sử dụng do các chủ thể có thể làm cạn kiệt tài nguyên đó

Mục tiêu an toàn có thể xây dựng dựa trên các chức năng thông qua nguyên tắc: *Đặc quyền tối thiểu*. Các chương trình được thực hiện các thao tác cần thiết cho hoạt động của chúng. Tuy nhiên, hạn chế chức năng không làm tăng tính an toàn của hệ thống mà chỉ làm giảm khả năng của việc tấn công.

b. **Mô hình tin cậy**

Mô hình tin cậy (*Trust model*) của hệ thống định nghĩa tập phần mềm và dữ liệu mà hệ thống dựa vào để đảm bảo thực hiện đúng đắn các mục tiêu an toàn của hệ thống. Với hệ điều hành, khái niệm này tương đồng với cơ sở tính toán tin cậy TCB (*trusted computing base*). Một cách lý tưởng, hệ thống tin cậy chứa số phần mềm tối thiểu để đảm bảo bắt buộc các mục tiêu an toàn. Phần mềm tin cậy bao gồm phần mềm xác định các yêu cầu an toàn của hệ thống và phần mềm thực thi các yêu cầu này. Hơn nữa, phần

mềm kích hoạt (khởi động) các phần mềm này cũng phải tin cậy. Để hệ điều hành hoạt động cần có phần mềm đăng nhập, xác thực người dùng, truy nhập tài nguyên nên các phần mềm này cần phải là phần mềm tin cậy.

Như vậy, người phát triển hệ điều hành an toàn phải chứng minh hệ thống của mình có mô hình tin cậy tồn tại. Để làm được điều này cần phải có:

- Phần mềm tin cậy phải thực hiện việc dàn xếp toàn bộ các thao tác nhạy cảm với an toàn. Nói cách khác, tất cả các thao tác nhạy cảm phải do phần mềm tin cậy đứng trung gian thực hiện.
- Chứng minh tính đúng đắn của phần mềm và dữ liệu tin cậy. Mức độ tin cậy của hệ thống thể hiện qua mức độ đánh giá (chứng minh) tính an toàn: từ một phần, kiểm thử toàn bộ hay đánh giá. Qua đó, người dùng có thể tin tưởng vào phần mềm để thực hiện công việc của mình.
- Chứng minh việc thực thi của các phần mềm không bị phá vỡ bởi các chương trình không nằm trong các phần mềm tin cậy. Nghĩa là, tính toàn vẹn của các phần mềm tin cậy phải được bảo vệ khỏi các mối đe dọa tới hệ thống. Rõ ràng, nếu phần mềm bị xâm nhập thì phần mềm đó không được tin cậy.

c. **Mô hình đe dọa**

Mô hình đe dọa (*Threat model*) xây dựng tập các thao tác mà người tấn công có thể dùng để vô hiệu hóa hệ thống. Trong mô hình này, giả định người tấn công chuyên nghiệp có khả năng chen dữ liệu vào mạng và có thể kiểm soát một phần các phần mềm đang chạy của hệ thống. Như vậy, tập các thao tác này không hạn chế theo nghĩa người tấn công có thể áp dụng bất cứ thao tác có thể để xâm phạm mục tiêu an toàn của hệ thống. Nhiệm vụ của người xây dựng hệ điều hành an toàn là bảo vệ các phần mềm tin cậy khỏi các dạng đe dọa trong mô hình.

Mô hình đe dọa cho thấy điểm yếu cơ bản của các hệ điều hành thương mại như Windows. Bởi, các hệ điều hành này giả định các phần mềm hoạt động nhân danh chủ thể thì được tin tưởng bởi chủ thể đó. Nói cách khác, người dùng tin tưởng vào các phần mềm mà họ sử dụng. Tuy nhiên, theo mô hình đe dọa thì các phần mềm này có thể bị kiểm soát bởi người tấn công. Vậy, hệ điều hành an toàn không thể tin tưởng các phần mềm nằm ngoài phạm vi an toàn (không tin cậy). Chương trình người dùng có thể không tin cậy song hệ thống có thể hạn chế việc truy nhập tới dữ liệu nhạy cảm nhằm hạn chế rò rỉ hay sửa đổi các thông tin này.

Nhiệm vụ của hệ điều hành an toàn là bảo vệ các phần mềm tin cậy khỏi các mối đe dọa được nhận biết từ mô hình nêu trên. Mục tiêu an toàn cần được đảm bảo bất kể hành vi hay hoạt động của các chương trình người dùng. Việc bảo vệ phần mềm tin cậy thường khó khăn hơn việc hạn chế rủi ro của các phần mềm người dùng do phải tương tác với nhiều tiến trình không tin cậy. Người phát triển hệ thống phải nhận biết được các

mối đe dọa, đánh giá ảnh hưởng của chúng lên an toàn hệ thống, và cung cấp biện pháp chống trả hiệu quả những đe dọa này.

d. **Cơ chế bảo vệ**

Hệ điều hành cung cấp cơ chế thực thi truy nhập tới các tài nguyên chung của hệ thống để người dùng thực hiện các hoạt động của mình thông qua phần mềm. Cơ chế thực thi truy nhập cho phép các yêu cầu (lời gọi hệ thống-system call) từ các chủ thể (subject) khác nhau như người dùng, tiến trình để thực hiện các thao tác (đọc ghi,...) lên các đối tượng (object) là tài nguyên của hệ thống. Đây là các khái niệm căn bản của hệ thống bảo vệ nhằm đảm bảo an toàn cho hệ điều hành. Điều cần chú ý là các truy nhập hệ thống hạn chế với các chủ thể và đối tượng bên trong hệ thống không phải từ bên ngoài.

Các dữ liệu cơ bản của hệ thống bảo vệ gồm có:

- Trạng thái bảo vệ mô tả các thao tác mà các chủ thể của hệ thống có thể thực hiện lên các đối tượng hệ thống
- Tập các thao tác lên trạng thái bảo vệ làm thay đổi các trạng thái này
- Hệ thống bảo vệ xác định các yêu cầu an ninh của hệ điều hành và thực hiện việc quản lý các yêu cầu này.

Một trong những biện pháp biểu diễn các trạng thái bảo vệ là sử dụng ma trận truy nhập như dưới đây.

Ma trận truy nhập

Các trạng thái bảo vệ của hệ thống được biểu diễn bằng ma trận truy nhập được định nghĩa bằng

- Tập các chủ thể S
- Tập các đối tượng O
- Các thao tác được phép của chủ thể lên đối tượng Op

	File 1	File 2	File 3	Process 1	Process 2
Process 1	Read	Read, Write	Read, Write	Read	-
Process 2	-	Read	Read, Write	-	Read

Hình 1-2. Ma trận truy nhập với hai tiến trình

Bên cạnh các thao tác cơ bản như đọc (read), ghi (write), ma trận cũng mô tả các thao tác mà chủ thể có thể thực hiện lên trên các ô của ma trận, chính là quyền sở hữu (own). Người có quyền sở hữu có thể thay đổi trạng thái bảo vệ (nội dung) của các ô tương ứng với đối tượng. Vì vậy, biện pháp bảo vệ này còn được gọi là tùy chọn.

Ma trận truy nhập cũng được sử dụng để mô tả miền bảo vệ (protection domain). *Miền bảo vệ* là tập các đối tượng (tài nguyên) mà tiến trình có thể truy nhập và các thao tác mà tiến trình có thể dùng để truy nhập tới các đối tượng như vậy. Việc duyệt qua nội dung của hàng trong ma trận truy nhập cho biết thông tin về miền hoạt động của tiến

trình như trong hình trên. Với hệ điều hành an toàn, cần đảm bảo miền an toàn của mỗi tiến trình thỏa mãn các mục tiêu an toàn như tính bí mật hay toàn vẹn.

Trên thực tế ma trận truy nhập có cấu trúc thừa, nghĩa là nhiều ô không có nội dung. Người ta có thể sử dụng các cách biểu diễn khác như sử dụng các cột thì ta có danh sách kiểm soát truy nhập ACL (*Access control list*). Hay sử dụng các hàng của ma trận thì ta có danh sách năng lực C-List (*Capability list*). ACL cho phép người quản trị hình dung được chủ thể nào có quyền gì với các đối tượng còn C-List giúp nhanh chóng xác định miền bảo vệ của tiến trình.

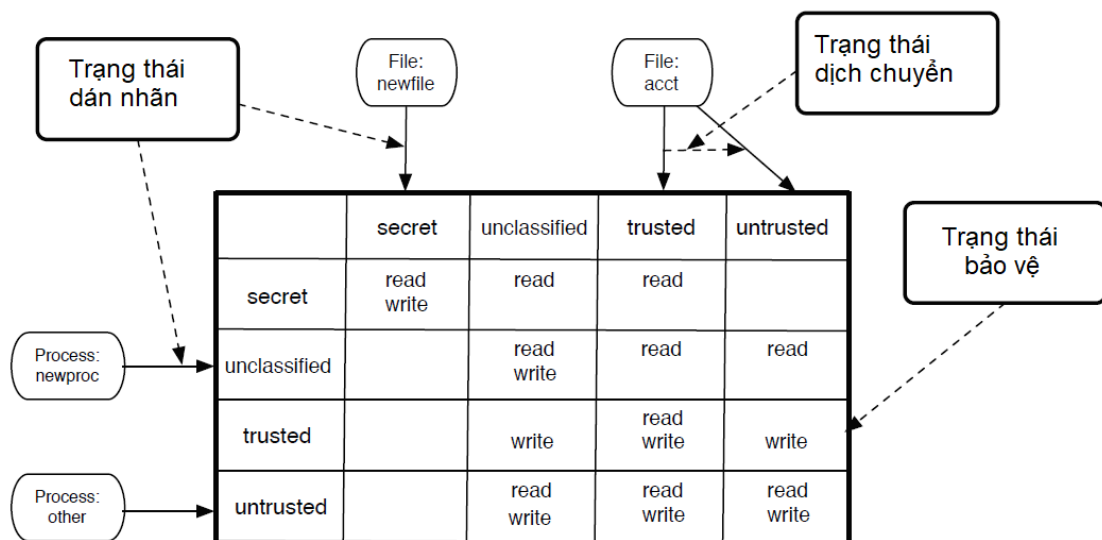
Mô hình bảo vệ sử dụng ma trận truy nhập làm nảy sinh vấn đề với an toàn hệ điều hành. Đó là các tiến trình không tin cậy có thể xâm nhập hệ thống bảo vệ. Lợi dụng các thao tác lên trạng thái bảo vệ, tiến trình người dùng không tin cậy có thể sửa đổi ma trận truy nhập bằng cách thêm chủ thể, đối tượng mới, hay các thao tác cho các ô của ma trận. Bài toán đảm bảo với trạng thái bảo vệ cụ thể và với toàn bộ các trạng thái bảo vệ có thể phát sinh từ trạng thái ban đầu không cho phép truy nhập trái phép xảy ra gọi là bài toán an toàn (*safety problem*). Người ta cho thấy rằng với các thao tác phức hợp như *tạo file*, thay đổi nội dung của cột và ô trạng thái người dùng, bài toán an toàn là không xác định được (*undecidable*). Như vậy, nói chung không thể kiểm chứng được trạng thái an toàn của hệ thống, tức là trạng thái xuất hiện các truy nhập không mong muốn với người sở hữu hay hệ thống. Khi này, hệ thống cần triển khai biện pháp bảo vệ bắt buộc.

Hệ thống bảo vệ bắt buộc

Như đã nêu trên, ma trận truy nhập không thể bảo vệ mục tiêu bí mật và toàn vẹn nhất là khi các chương trình người dùng không tin cậy. Để đảm bảo mục tiêu của hệ thống, các trạng thái bảo vệ cần được định nghĩa dựa trên việc xác định chính xác mục tiêu bí mật và toàn vẹn của dữ liệu và chương trình người dùng. Thêm vào đó không cho phép bất cứ chương trình không tin cậy nào được phép thực hiện các thao tác sửa đổi thông tin bảo vệ. Các yêu cầu này làm xuất hiện hệ thống bảo vệ bắt buộc.

Hệ thống bảo vệ bắt buộc là hệ thống mà chỉ có thể được sửa đổi bởi người quản trị tin cậy thông qua phần mềm tin cậy gồm các biểu diễn trạng thái như sau:

- *Trạng thái bảo vệ bắt buộc* là trạng thái mà các chủ thể và các đối tượng được biểu diễn bằng các nhãn. Các trạng thái mô tả các thao tác mà các nhãn chủ thể có thể thực hiện lên các nhãn đối tượng.
- *Trạng thái dán nhãn* để ánh xạ các tiến trình và các đối tượng tài nguyên hệ thống tới các nhãn
- *Trạng thái dịch chuyển* mô tả cách thức hợp lệ mà các tiến trình và các đối tượng có thể được dán nhãn lại (thay đổi nhãn).



Hình 1-3. Hệ thống bảo vệ bắt buộc

Trong hệ điều hành an toàn, nhãn chính là các định danh khái quát. Việc gán quyền cho nhãn xác định ngữ nghĩa (*semantics*) an toàn của chúng. Các nhãn này chống lại việc xâm nhập (*temper-proof*) nhờ:

- Tập các nhãn này được xây dựng bởi người quản trị tin cậy bằng phần mềm tin cậy
- Tập các nhãn không thay đổi được bởi các tiến trình không tin cậy của người dùng

Người quản trị tin cậy xây dựng các nhãn của ma trận truy nhập và xác lập các thao tác mà chủ thể với nhãn nhất định được phép thực hiện lên trên đối tượng với nhãn cho trước. Hệ thống này cho phép miễn nhiệm với các tiến trình không tin cậy. Điều này là vì tập các nhãn không thể thay đổi qua việc thực thi của các tiến trình người dùng, có thể chứng minh được các mục tiêu an toàn được thực thi qua ma trận và trong suốt quá trình hoạt động của hệ thống.

Hệ điều hành an toàn cần có khả năng gán các nhãn cho các chủ thể (tiến trình) và đối tượng được tạo ra trong quá trình hoạt động và thậm chí cho phép thay đổi nhãn. Trạng thái dán nhãn chỉ là quá trình gán các nhãn cho chủ thể và đối tượng mới. Hình 1-3 cho thấy các tiến trình và các file được liên kết với các nhãn trong một tình huống cố định. Khi newfile được tạo ra cần gán cho nó một nhãn trong trạng thái an toàn cụ thể là nhãn secret. Tương tự tiến trình newproc được gán nhãn unclassified. Như vậy, ma trận truy nhập cho thấy tiến trình mới này không có quyền gì với file mới được tạo ra.

Trạng thái chuyển dịch cho phép hệ điều hành an toàn thay đổi nhãn của tiến trình (chủ thể) hay tài nguyên hệ thống (đối tượng). Với tiến trình, việc này làm thay đổi miền bảo vệ hay các tài nguyên được phép sử dụng. Việc này cần thiết khi xét đến khả năng một tiến trình kích hoạt chương trình khác chạy. Như vậy, nhãn gán với tiến trình cần thay đổi thể hiện các yêu cầu truy nhập hay tin cậy trong môi trường (miền) mới. Với hệ

điều hành an toàn, trạng thái chuyển dịch phải được xác định bởi người quản trị tin cậy và không bị thay đổi trong quá trình thực thi hệ thống.

1.2 Các vấn đề về kiến trúc an toàn

Việc xây dựng hệ thống máy tính cần tìm kiếm sự cân bằng giữa một loạt các yêu cầu như năng lực, tính mềm dẻo, hiệu năng, chi phí. Trong khi không có xung đột hiển nhiên giữa các yêu cầu này thì các tính năng liên quan tới an toàn thường xung đột với nhau và cần phải thỏa hiệp trong khi thiết kế hệ thống. An toàn đơn giản là một dạng yêu cầu khác và nếu có xung đột các tính năng an toàn phải cân đối với các tính năng khác tùy theo mức độ quan trọng với hệ thống. Kiến trúc an toàn (*security architecture*) đóng vai trò thiết yếu trong quá trình phân tích thiết kế hệ thống.

Kiến trúc an toàn là mô tả chi tiết toàn bộ các khía cạnh của hệ thống liên quan đến vấn đề an toàn cùng với các nguyên tắc thiết kế. Kiến trúc an toàn tốt giống như thiết kế tổng thể mô tả ở mức khái quát quan hệ giữa các bộ phận then chốt theo cách mà chúng phải thỏa mãn các yêu cầu về an toàn. Mặt khác, kiến trúc này cần mô tả các chi tiết của quá trình xây dựng hệ thống mà qua đó các yêu cầu an toàn được đảm bảo. Kiến trúc an toàn cho phép mô tả và xác định các mục tiêu an toàn mà hệ thống cần phải đạt được. Việc này không chỉ giúp trong những giai đoạn đầu thiết kế hệ thống mà cả sau này khi vận hành.

Tại thời điểm bắt đầu xây dựng hệ thống, kiến trúc an toàn có thể được mô tả bằng các vấn đề an toàn ở mức cao: chính sách an toàn, mức độ đảm bảo mong muốn, tác động của an toàn lên quá trình xây dựng hệ thống, và các nguyên tắc hướng dẫn chung. Sau này, khi được định hình rõ ràng, kiến trúc an toàn cần phản ánh cấu trúc của hệ thống và mức độ chi tiết tăng dần theo các bước thiết kế. Tuy vậy, kiến trúc cần đi trước một bước để định hướng cho việc hoàn thành công việc thiết kế. Kiến trúc an toàn đóng vai trò quan trọng trong khi phát triển và tác động tới từng cá nhân riêng lẻ thông qua các hướng dẫn thể hiện qua các tiêu chuẩn lập trình, đánh giá mã và kiểm thử.

Các vấn đề cần xây dựng kiến trúc an toàn được xem xét như dưới đây.

1.2.1 Xem xét vấn đề an toàn ngay từ đầu

Ngay từ đầu, người thiết kế hệ thống cần coi trọng vấn đề an toàn ngang bằng như các tính năng vận hành của hệ thống và phải được tích hợp đầy đủ vào hệ thống. Nhiều trường hợp, người thiết kế và phát triển sử dụng chính sách “xây dựng trước, an toàn sau”. Như vậy vấn đề an toàn không được tích hợp tốt vào hệ thống. Việc thiếu quan tâm đến vấn đề an toàn sẽ dễ dẫn đến việc không kiểm soát được các phí tổn để bổ sung các tính năng an toàn.

1.2.2 *Lường trước các yêu cầu về an toàn*

Kiến trúc an toàn cần có tầm nhìn xa để cập tới các tính năng an toàn tiềm năng thậm chí chưa có kế hoạch sử dụng ngay lập tức. Việc này làm tăng chi phí một chút cho việc nâng cao tính an toàn. Điểm then chốt cho việc gắn kết hợp lý các tính năng an toàn tương lai là việc hiểu rõ các yêu cầu về an toàn của hệ thống máy tính nói chung. Hơn thế cần phải mô tả một cách tường minh nhất các yêu cầu trong tương lai này trong kiến trúc an toàn. Thực tế cho thấy rằng an toàn của nhiều hệ thống máy tính không thể được cải thiện do các chức năng của hệ thống được xây dựng dựa trên các đặc điểm không an toàn. Khi các đặc điểm này thay đổi, hệ thống sẽ không hoạt động như kỳ vọng. Trong nhiều trường hợp, việc khắc phục các lỗ hổng này có thể làm hỏng các phần mềm đang chạy tốt. Lường trước các yêu cầu an toàn không chỉ ảnh hưởng đến mức độ cần thiết làm hệ thống an toàn hơn trong tương lai mà còn giúp xác định liệu tính an toàn của hệ thống có thể được nâng cao hay không.

Vấn đề khác là chính sách an toàn. Thay đổi trong chính sách an toàn có thể dẫn đến hậu quả tai hại với các ứng dụng đang hoạt động tốt mà nay xung đột với chính sách mới. Mặt khác quan tâm tới các chính sách an toàn ngay khi xây dựng ứng dụng, ngay cả khi các chính sách chưa thực thi, làm cho việc thay đổi nếu có được trơn tru và trong suốt.

1.2.3 *Giảm thiểu và cách ly các biện pháp an toàn*

Để đạt được độ tin cậy cao về an toàn của hệ thống, người thiết kế cần giảm thiểu kích cỡ và độ phức tạp của các phần liên quan tới an toàn của thiết kế. Lý do chính khiến hệ điều hành không an toàn là kích cỡ quá lớn của chúng làm cho khó nắm bắt tổng thể hệ thống và hệ điều hành khó có thể hoàn toàn sạch lỗi và khó tin cậy. Vì vậy, ngay cả với hệ thống phức tạp, cần giữ phần cốt lõi (liên quan đến an toàn) nhỏ và định nghĩa rõ ràng.

Điểm then chốt để giảm thiểu các bộ phận liên quan tới an toàn của hệ điều hành là chỉ dùng số ít các cơ chế thực thi an toàn. Như vậy, bắt buộc các hành động liên quan tới an toàn được giữ trong một số ít phần cách ly. Thực tế với hệ điều hành rất khó đặt được điều này. Vấn đề an toàn liên quan tới rất nhiều chức năng khác nhau của hệ thống như quản lý file hệ thống, quản lý bộ nhớ ...

Khi các cơ chế an toàn đơn giản, dễ nhận biết và cách ly thì dễ dàng triển khai các cơ chế bảo vệ bổ sung để tránh các thiệt hại do lỗi tại các phần khác của hệ thống. Các đoạn mã liên quan đến an toàn có thể bảo vệ chống ghi để không bị sửa đổi.

1.2.4 *Thực hiện quyền tối thiểu*

Gắn với khái niệm cách ly các cơ chế an toàn là nguyên tắc quyền tối thiểu. Các chủ thể (người dùng hay chương trình) cần được cấp quyền không hơn mức cần thiết để thực hiện công việc. Như vậy, thiệt hại do lỗi hay phần mềm xấu được hạn chế. Quyền tối thiểu được biểu diễn trong nhiều khía cạnh của hệ thống.

Thông thường, quyền thể hiện ở các cơ chế phân cứng hạn chế việc sử dụng các câu lệnh đặc biệt (lệnh vào/ra) và truy nhập tới các vùng ô nhớ. Ngoài ra, quyền còn thể hiện ở các cơ chế phần mềm, như trong hệ điều hành, cho phép chương trình người dùng qua các biện pháp kiểm soát truy nhập hay thực thi các chức năng hệ thống.

Quyền tối thiểu còn thể hiện trong nguyên tắc phát triển hệ thống. Như bằng việc đặt ra các tiêu chuẩn lập trình hạn chế các truy nhập tới các dữ liệu toàn cục (*global data*), như vậy giảm khả năng lỗi từ vùng này tác động tới vùng khác. Việc quản trị người dùng và hệ thống là một khía cạnh khác của quyền tối thiểu. Người dùng và người quản trị không nên được cấp truy nhập nhiều hơn với công việc của họ.

1.2.5 Giữ các tính năng an toàn thân thiện

Các cơ chế an toàn không được ảnh hưởng tới người dùng tuân thủ quy định. Cơ chế an toàn phải trong suốt với người dùng bình thường. Việc can thiệp vào công việc hàng ngày làm giảm năng suất và khiến người dùng tìm cách bỏ qua các cơ chế an toàn.

Các cơ chế an toàn cần thuận tiện cho người dùng để cấp quyền truy nhập. Người dùng cần được đảm bảo cung cấp đủ truy nhập khi cần thiết và tránh các thủ tục rườm rà và phức tạp.

Để thuận tiện cho người dùng để hạn chế truy nhập có thể thực hiện cách xây dựng các chế độ mặc định phù hợp. Việc này hạn chế các rủi ro do vô tình khi quản lý và cấp phát các quyền truy nhập cho người dùng.

1.2.6 An toàn không dựa trên bí mật

Ngoại trừ việc quản lý mật khẩu, đỉnh chính của kiến trúc an toàn tránh phụ thuộc vào tính bí mật để đảm bảo an toàn. Việc giả định người dùng không thể bẻ khóa hệ thống vì không biết mã nguồn hay tài liệu về hệ thống không an toàn chút nào.

Việc công khai mã nguồn hệ thống có khả năng cải thiện tính an toàn nhờ có khối lượng người dùng lớn hơn giúp phát hiện và sửa chữa các khiếm khuyết.

1.3 Chính sách an toàn

Từ góc độ quản lý, công việc quản trị cần mô tả và xây dựng các yêu cầu và các hành động cụ thể để đảm bảo sự tuân thủ chính sách, quy trình, tiêu chuẩn và hướng dẫn của cơ quan/tổ chức. Việc quản trị tốt mang lại sự tin tưởng và tự tin về các thành viên tuân theo các qui định đã được xây dựng. Về cơ bản, chính sách an toàn mô tả các kiểm soát, hành động, và quy trình cần được thực hiện cho hệ thống thông tin. Các chính sách cần đề cập và xử lý các mối đe dọa tới hệ thống bao gồm cả con người, thông tin và tài sản cụ thể. Hệ điều hành là hệ thống cho phép người dùng thông qua các chương trình máy tính truy nhập vào các tài nguyên của máy tính cũng như là các tài nguyên (thông tin) nhạy cảm với an toàn và thực thi các thao tác trên các tài nguyên này. Việc truy nhập cũng như

xử lý này chịu sự ràng buộc và hạn chế thể hiện trong các chính sách của cơ quan/tổ chức và do người quản trị thực thi qua các công cụ quản trị của hệ thống.

Sự thành công của các biện pháp bảo vệ tài nguyên của hệ thống tùy thuộc vào các chính sách được xây dựng và thái độ quản lý tới việc đảm bảo an toàn thông tin. Những người xây dựng chính sách xác lập tinh thần và tầm quan trọng của vấn đề an toàn thông tin của hệ thống nhằm để: giảm thiểu rủi ro; phù hợp với các quy định và luật pháp; đảm bảo việc hoạt động liên tục, tính bí mật và toàn vẹn thông tin. Mặt khác, các chính sách cần phải được hỗ trợ và quản trị một cách thích đáng. Các chuyên gia an toàn thông tin duy trì an ninh thông qua thực thi các chính sách hay thực hiện các hướng dẫn về các hành vi được và không được chấp nhận tại nơi làm việc một cách bắt buộc với các thành viên.

Chính sách chung dùng để mô tả và xây dựng định hướng và tầm nhìn chung. Nói cách khác, chính sách này xác lập mong muốn về việc bảo vệ các tài sản thông tin. *Chính sách cho ứng dụng cụ thể* hướng tới các ứng dụng cụ thể sau khi đã định hình được các yêu cầu cũng như biện pháp đảm bảo an toàn cần thiết. Các quyết định về an ninh hay an toàn sẽ chỉ áp dụng cho các ứng dụng cụ thể như: ai là người có thẩm quyền sửa đổi dữ liệu? Việc truy nhập từ xa được kiểm soát như thế nào? Việc sử dụng các kết nối mạng ra làm sao? Như vậy, cách chính sách ở mức này liên quan trực tiếp đến các yêu cầu an toàn cho các hoạt động cụ thể của cơ quan/tổ chức.

Một cách chặt chẽ, hệ thống máy tính cần tuân thủ các thuộc tính (mục tiêu cần đạt) về an toàn và an ninh trong khi người dùng cần tuân thủ các chính sách an toàn. Việc xác định và xây dựng các thuộc tính an toàn chỉ có thể hoàn thành khi xác định được các yêu cầu cụ thể về an toàn thông qua các chính sách được mô tả. Thiếu sót trong việc xây dựng cách chính sách rõ ràng và tường minh khiến cho việc thực thi không nhất quán và làm nảy sinh các lỗ hổng khó khắc phục.

Từ góc độ vận hành, các chính sách an toàn cần được chuyển hóa thành các luật trong các bộ phận thực hiện chức năng kiểm soát truy nhập tới các tài nguyên của hệ thống như hệ thống file, mạng, bộ nhớ... Mặt khác bộ phận kiểm soát cần thiết đánh giá và kiểm chứng các chính sách này có xung đột với nhau hay vi phạm các nguyên tắc an toàn chung của hệ thống hay không.

1.4 Nền tảng tính toán tin cậy

1.4.1 Khái niệm

Máy tính ngày nay sử dụng kiến trúc mở cho phép người dùng toàn quyền lựa chọn phần mềm cũng như khả năng đọc, xóa hay sửa dữ liệu lưu trữ trên máy tính. Điều này dẫn đến các vấn đề tiêu biểu sau:

- Không an toàn cho người dùng vì kiến trúc mở có nguy cơ bị lây nhiễm vi-rút, sâu hay vô tình cài đặt phần mềm xấu

- Không an toàn cho mạng mà máy tính kết nối vào do máy tính này có thể chứa phần mềm xấu có thể đe dọa máy tính khác trong mạng
- Không an toàn cho người sản xuất phần mềm và nội dung do kiến trúc mở cho phép các chương trình, file âm nhạc ... có thể bị sao chép không giới hạn và không bị giảm chất lượng

Khái niệm tính toán tin cậy đã được trình bày khá lâu trong lĩnh vực an toàn máy tính và có ảnh hưởng tới việc thiết kế các thể hệ máy tính phổ thông như PC, thiết bị di động. Tính toán tin cậy đòi hỏi thiết kế lại kiến trúc hệ thống sao cho các thành phần riêng lẻ được định nghĩa một cách tường minh các đặc tính của mình. Điều này cho phép người thiết kế có thể xác định chính xác hành vi của hệ thống.

Tính toán tin cậy mô tả các sửa đổi cần thiết về phần cứng và phần mềm để cung cấp nền tảng ổn định để hệ thống máy tính có thể hoạt động trên đó. Hệ thống này có đặc tính:

- Độ đảm bảo cao về trạng thái (cấu hình, tình trạng hoạt động của phần mềm ...) của hệ thống máy tính cục bộ. Do vậy có thể xác định khả năng chấp nhận các tác động không mong muốn
- Mức độ đảm bảo cao tương đối về trạng thái của hệ thống ở xa. Điều này thể hiện độ tin cậy của việc tương tác trong hệ thống phân tán.

Việc triển khai tính toán tin cậy gặp nhiều thách thức khác nhau. Trước hết, các máy tính và phần mềm được cung cấp từ nhiều nhà sản xuất và phân phối khác nhau dẫn đến khó khăn trong việc xác định mức độ ổn định và tin cậy của hệ thống máy tính cũng như là phần mềm. Thêm vào đó, hầu hết hệ điều hành được thiết kế dựa trên ý tưởng có 1 người quản trị hệ thống chuyên nghiệp trong khi người dùng cuối thường thiếu kỹ năng và hiểu biết. Nhiều rủi ro xuất hiện do sự bất cẩn của người dùng cuối.

Các vấn đề tương tự cũng gặp phải với các hệ thống mạng. Người dùng không thể tiếp xúc trực tiếp với các hệ thống máy chủ cung cấp dịch vụ. Như vậy, người dùng phải chấp nhận giả định hệ thống máy tính tin cậy và được quản trị bởi đội ngũ phù hợp.

Nền tảng di động là ví dụ tiêu biểu với tính toán tin cậy vì có yêu cầu tin cậy chặt chẽ hơn máy tính cá nhân PC. Các thiết bị vô tuyến cần tuân thủ chặt chẽ các quy định quan trọng như không cho phép phần mềm thay đổi tùy ý các tham số hoạt động. Thời gian hoạt động cũng có thể được tính tiền và phải được gán một cách chính xác tới thuê bao. Hơn thế, thiết bị di động có thể có những cách sở hữu phức tạp như người dùng cuối có thể đăng ký sử dụng nhiều thiết bị và dịch vụ khác nhau. Các thiết bị này cũng dễ bị thất lạc và mất trộm hơn là máy tính để bàn truyền thống. Chính vì các yêu cầu khắt khe hơn và thu hút được sự quan tâm hơn từ nhà sản xuất cũng như người dùng, nền tảng tính toán tin cậy trên di động có nhiều kết quả hơn so với PC truyền thống.

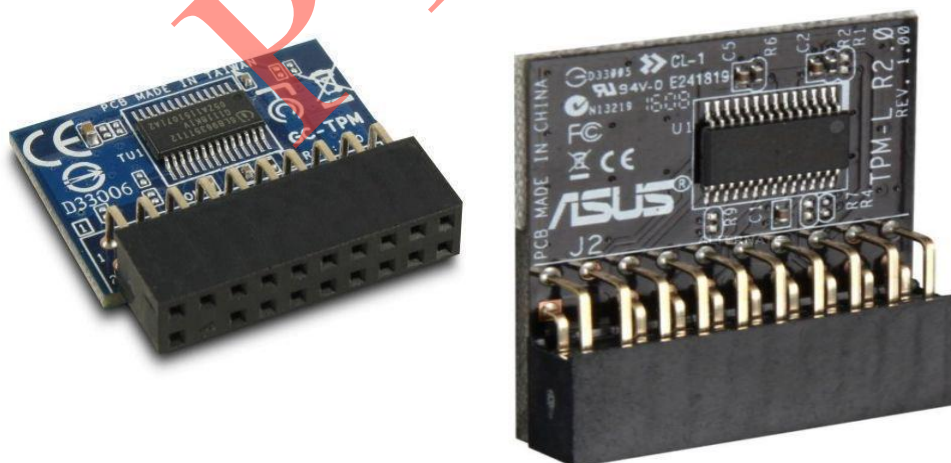
1.4.2 Mô đun hạ tầng tính toán tin cậy

a. Giới thiệu

Để có thể đảm bảo an toàn với việc sử dụng các thiết bị tính toán trên máy tính PC, về cơ bản cần:

- Các máy tính được định danh một cách chắc chắn có thể thông qua việc sử dụng khóa công khai kèm với khóa bí mật “gắn chặt” liền với hạ tầng tính toán. Như vậy cần sử dụng cơ chế phần cứng và chống xâm nhập hay giả mạo.
- Các máy tính xác định chắc chắn cấu hình và định danh chương trình nhờ sử dụng mã băm và cơ chế khác. Phần mềm, firmware, BIOS, trình nạp, nhân, chương trình tham gia vào quá trình hoạt động của máy tính cần được kiểm tra thích đáng để đảm bảo mức độ tin cậy và thực thi đúng đắn chính sách an ninh mong muốn.

Mô-đun hạ tầng tin cậy TPM (*Trusted Platform Module*) được định nghĩa là các chức năng phần mềm (lô-gíc) và nhúng vào trong kiến trúc của máy tính bằng cách sử dụng chip riêng biệt. Mô-đun này cung cấp cơ sở để đảm bảo an toàn cho các chương trình máy tính trong quá trình hoạt động cũng như tương tác với nhau thông qua việc sử dụng các cơ chế định danh và mã hóa. Các chức năng của TPM được xây dựng bằng phần mềm, song các chức năng an ninh cần được bảo vệ chặt chẽ được thực hiện thông qua thiết bị phần cứng. Hình dưới đây cho thấy các mô-đun TPM từ các nhà sản xuất khác nhau.



Hình 1-4. Mô đun TPM phần cứng

Về cơ bản, tính toán tin cậy cần thiết bị lưu trữ được bảo vệ mà thiết bị này chỉ có thể truy nhập qua các giao tiếp đặc biệt và không sử dụng các thức đọc ghi thông thường như với thanh ghi hay bộ nhớ. Cách này tương tự như việc truy nhập thông tin trên thẻ tín dụng. Việc này cho phép TPM mã hóa các thông tin bằng mã khóa chỉ tồn tại bên trong TPM và giúp bảo vệ dữ liệu được lưu trữ. Chi tiết về cách thức sử dụng mô-đun TPM

trong việc đảm bảo hoạt động an toàn cho các chương trình máy tính nói chung và hệ điều hành nói riêng sẽ được giới thiệu chi tiết trong chương sau. Phần này chỉ nhằm giới thiệu tổng quan các chức năng an toàn cơ bản mà mô-đun TPM cung cấp.

b. *Các dịch vụ an toàn*

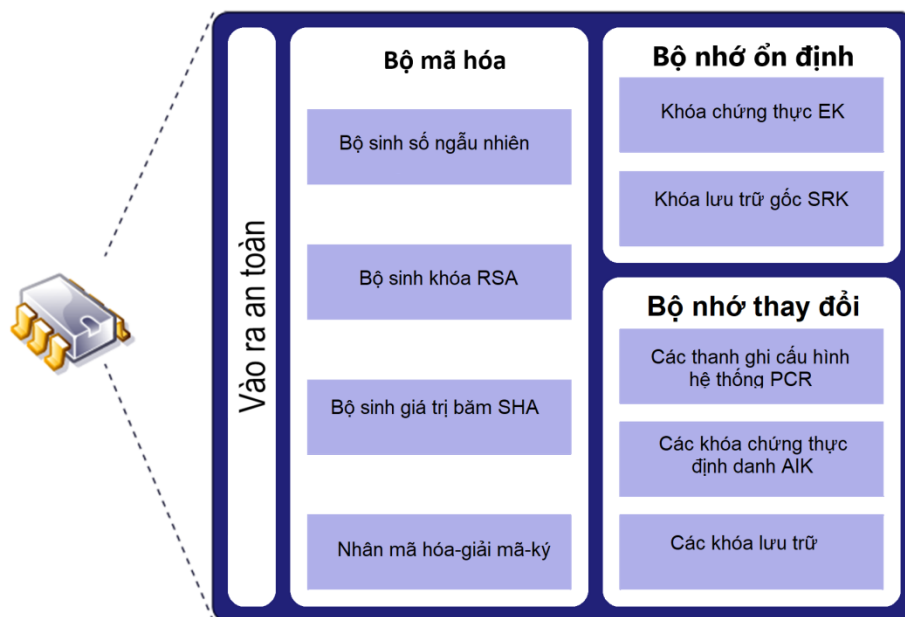
TPM khi được nhúng vào bên trong hệ thống PC nhằm cung cấp và đảm bảo các cơ sở tin cậy sau:

- Cơ sở tin cậy cho việc tính toán (*Root of Trust for Measurement- RTM*): triển khai một cách tin cậy các thuật toán băm chịu trách nhiệm cho các biện pháp bảo vệ đầu tiên với hạ tầng tính toán như tại thời điểm khởi động hay xác lập trạng thái tin cậy của hệ thống.
- Cơ sở lưu trữ tin cậy (*Root of Trust for storage - RTS*) : triển khai tin cậy vị trí được bảo vệ cho việc lưu trữ một hay nhiều khóa bí mật và một khóa lưu trữ gốc SRK (*storage root key*);
- Cơ sở tin cậy cho việc báo cáo (*Root of Trust for reporting-RTR*): triển khai tin cậy vị trí được bảo vệ để lưu khóa bí mật đại diện cho định danh duy nhất của hạ tầng, còn gọi là khóa chứng thực EK (*endorsement key*).

Các khóa SRK và EK sử dụng cách mã hóa di bộ (cơ chế mã hóa dùng khóa công khai). TPM có nhiệm vụ bảo vệ khóa bí mật trong cặp khóa trên. Phần khóa công khai EK được đăng ký với nơi chứng thực. Khóa EK tồn tại không đổi trong suốt thời gian hoạt động của hạ tầng tính toán và được sử dụng cho một số hạn chế các thủ tục. Điều này là vì EK là duy nhất cho mỗi thiết bị TPM và có thể được dùng để nhận dạng thiết bị. Trong một số tình huống, người dùng có thể tự quản lý khóa EK này. Tuy nhiên khi này người dùng không thể cung cấp chứng thực cho khóa nên việc ứng dụng bị hạn chế. SRK được thiết lập khi triển khai cho người dùng và có thể được khởi tạo lại khi thay đổi người dùng thông qua cơ chế xác lập quyền sở hữu với thiết bị TPM.

Các bộ phận cơ bản cấu thành mô-đun TPM được trình bày trong Hình 1-5. Các khóa chứng thực định danh AIK (*Attestation Identity Key*) được tạo ra nhằm xác định định danh của hệ thống mà không phải cung cấp EK như là khóa dùng để ký. Việc này nhằm đảm bảo tính riêng tư của người sử dụng trong tình huống các nhà cung cấp dịch vụ yêu cầu bằng chứng về định danh người dùng.

Các thanh ghi cấu hình hệ thống PCR (*Platform Configuration Register*) được dùng để lưu lại các giá trị đo tính toàn vẹn của hệ thống. Các giá trị lưu trong các thanh ghi này có thể tính toán độ toàn vẹn của bất cứ đoạn mã nào từ BIOS tới các ứng dụng chủ yếu là trước khi đoạn mã được thực hiện. TPM có tối thiểu 16 thanh ghi kiểu này, trong đó 8 thanh ghi đầu dành riêng cho TPM.



Hình 1-5. Các bộ phận chức năng của TPM

Bộ phận RTM và RTR là các bộ phận cơ bản để thiết lập tin cậy cũng như với bên thứ ba. Nhờ vào thủ tục “niêm phong”, bộ phận RTS xác lập sự tin cậy với hệ thống cục bộ. Đồng thời RTS cũng giúp bảo vệ tính bí mật cũng như cung cấp lưu trữ được bảo mật cho các ứng dụng hay người dùng không tin cậy lẫn nhau.

Bộ phận mã hóa là phần thực thi các hàm cần thiết dùng cho việc cung cấp các dịch vụ an toàn của mô-đun TPM như tạo số ngẫu nhiên, tính toán giá trị băm, ký số,...

c. **Khởi tạo TPM**

Các thẻ thông minh nói chung được sở hữu và tùy chỉnh bởi bên cấp thẻ trước khi người dùng nhận được thiết bị này. Tuy vậy, nhóm đề xuất tính toán tin cậy TCG (*Trusted Computing Group*) hiểu rõ tình huống các hệ thống sử dụng TPM có thể bị kiểm soát bởi các tổ chức lớn từ xa. Vì vậy, TCG đã rất cẩn thận cung cấp cơ chế để chỉ người dùng được sở hữu và đặt cấu hình TPM. Nói cách khác, chỉ có người dùng sở hữu TPM xác định trạng thái TPM theo mong muốn của mình chứ không phải là nhà cung cấp.

Khi người dùng lấy quyền sở hữu của TPM, người ta thiết lập một bí mật dùng cho chia sẻ, thường được gọi là dữ liệu ủy quyền chủ sở hữu (*owner authorisation data*) và chèn dữ liệu này vào nơi lưu trữ an toàn trong TPM. Trên thực tế, đây chính là mật khẩu của người dùng và việc có thể chứng tỏ việc nắm giữ bí mật này cung cấp bằng chứng về quyền sở hữu. Ngay sau khi được sở hữu, TPM có thể kiểm soát việc truy nhập tới các thao tác được bảo vệ nhất định qua việc yêu cầu bằng chứng của việc sở hữu mà việc này có thể được thực hiện thông qua việc cung cấp dữ liệu ủy quyền chủ sở hữu.

Quá trình lấy quyền sở hữu yêu cầu dữ liệu ủy quyền sở hữu được bảo vệ khỏi việc nghe trộm hay bên thứ ba. Đây là tình huống chứng nhận chứng thực được sử dụng do khóa chứng thực EK là khóa duy nhất mà TPM chưa từng được sử dụng (sở hữu) có. Chính khóa EK này thiết lập kênh an toàn để trao đổi dữ liệu ủy quyền tới TPM hợp lệ.

Như vậy, trong quá trình lấy quyền sở hữu, người chủ sở hữu yêu cầu chứng nhận chứng thực và sau khi kiểm tra thông tin này xong, nhận được khóa công khai EK để mã hóa bí mật chia sẻ. Chỉ có TPM hợp lệ được xác định nhờ thông tin chứng nhận chứng thực này truy nhập vào khóa bí mật EK và như vậy chỉ có TPM được chỉ định mới có được bí mật chia sẻ này. Quá trình lấy quyền sở hữu hoàn tất bằng việc tạo ra khóa lưu trữ gốc SRK mà nó được TPM sinh ra và lưu trữ trong phần bộ nhớ ổn định (*non-volatile*). Cũng giống như khóa bí mật EK, khóa SRK không bao giờ ra khỏi TPM.

1.4.3 Các tác động

Các tiếp cận của tính toán tin cậy làm thay đổi mạnh mẽ thiết kế của hệ thống máy tính để bàn và ứng dụng phân tán. Điều mới với tính toán tin cậy là việc đảm bảo chắc chắn phần mềm chạy cục bộ hay ở xa dựa trên cơ chế mã hóa sử dụng cách thức xác thực đảm bảo. Tính toán tin cậy ngăn chặn các vụ tấn công dựa trên phần mềm nhờ vào các thao tác thiết yếu cho hoạt động phải có sự chứng thực từ phần cứng TPM.

Tính toán tin cậy chịu nhiều chỉ trích không chỉ từ cộng đồng mã nguồn mở từ những điểm tiêu biểu như sau:

- Tính riêng tư: Không bảo vệ danh danh người dùng với một số giao dịch
- Kiểm soát của bên bán hàng: Bên bán hàng có thể sử dụng TPM khiến cho việc lựa chọn và thay đổi sản phẩm khó khăn hơn với người dùng cuối
- Chứng thực: Việc chứng thực sử dụng chữ ký khó khăn do số lượng phần mềm lớn, nhất là khi các phần mềm này có thể được cập nhật định kỳ, vì vậy việc chứng thực cần thực hiện trên cơ sở hành vi của chương trình.
- Không hỗ trợ mã khóa đối xứng. Thiết kế của TPM dù dùng rất nhiều phần của bộ xử lý mã hóa song không cung cấp chức năng mã hóa đối xứng nào. Điều này ảnh hưởng tới vấn đề như thực thi luật pháp.
- Thực thi luật pháp: việc mã khóa mạnh tác động cả hai bên người dùng hợp lệ và người bẻ khóa. Được dùng một cách đúng đắn, TPM giúp bảo vệ dữ liệu bí mật của người dùng. TPM mô tả một cách rõ ràng không có cửa hậu trong thiết bị hợp chuẩn. Như vậy, không có cách thức hợp lệ nào khác ngoài thông tin của chủ sở hữu để truy nhập vào các thông tin được bảo vệ. Ngược lại, khi bị lạm dụng sẽ rất khó khăn cho các cơ quan thực thi luật pháp để khai thác các thông tin bí mật này.

1.5 Nhân an toàn

Về mặt kỹ thuật, hệ điều hành an toàn cần có nền tảng nhỏ và có thể kiểm chứng được để xây dựng an toàn của hệ thống. Phần cơ sở nền tảng này còn được gọi là nhân an toàn (*security kernel*). Nhân an toàn được xác định bằng phần cứng và phần mềm cần thiết để thực thi các chính sách của hệ thống. Các quyết định truy nhập được mô tả bởi các chính sách dựa trên các thông tin trong cơ sở dữ liệu về kiểm soát truy nhập. Cơ sở

dữ liệu này thể hiện trạng thái an toàn của hệ thống và chứa các thông tin như quyền truy nhập và các thuộc tính an ninh. Cơ sở dữ liệu này động và thay đổi do các chủ thể và đối tượng được tạo và xóa cũng như quyền truy nhập của chúng được sửa đổi. Yêu cầu tối quan trọng là giám sát việc tham chiếu của từng thao tác từ chủ thể tới đối tượng.

1.5.1 Các yêu cầu an toàn

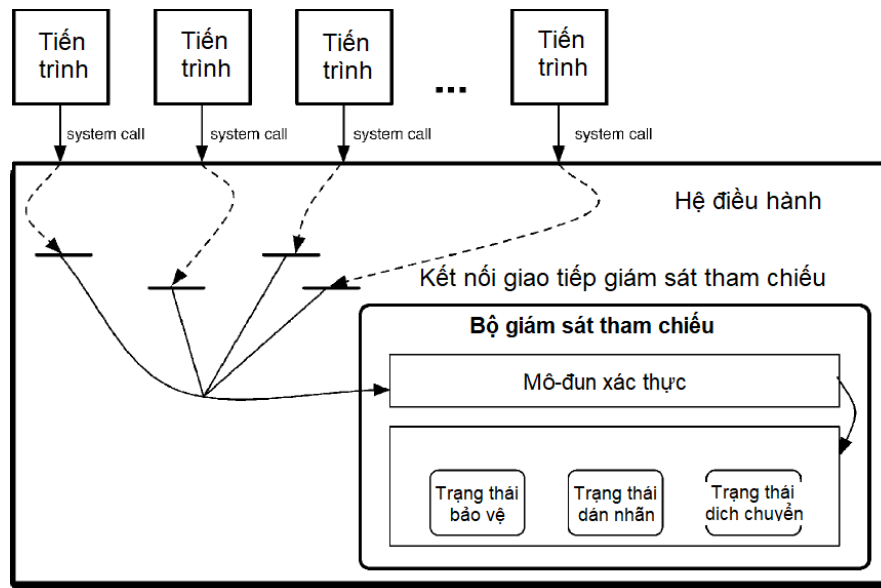
Hệ điều hành an toàn là hệ điều hành mà việc thực thi truy nhập thỏa mãn các yêu cầu của giám sát tham chiếu. Bộ giám sát tham chiếu xác định các thuộc tính cần và đủ của bất kỳ hệ thống nào để thực thi hệ thống bảo vệ một cách an toàn. Các thuộc tính của bộ giám sát tham chiếu đảm bảo yêu cầu an toàn:

- *Ngăn chặn hoàn toàn (complete mediation)*: hệ thống đảm bảo cơ chế thực thi truy nhập ngăn chặn toàn bộ các thao tác nhạy cảm với an ninh
- *Chống xâm nhập (tamper-proof)*: hệ thống đảm bảo có chế thực thi truy nhập, kể cả hệ thống bảo vệ, không thể bị sửa đổi bởi các tiến trình (chương trình) không tin cậy
- *Thẩm tra được (verifiable)*: Cơ chế thực thi truy nhập, kể cả hệ thống bảo vệ, phải đủ nhỏ để có thể kiểm tra và phân tích, tính đúng đắn của nó có thể được đảm bảo. Nói cách khác, phải có khả năng chứng minh hệ thống thực thi các mục tiêu an toàn một cách đúng đắn

1.5.2 Giám sát tham chiếu

Giám sát tham chiếu (*Reference Monitor*) là cơ chế thực thi truy nhập cổ điển. Khi có yêu cầu truy nhập, bộ phận giám sát trả lời chấp nhận hay từ chối truy nhập dựa vào chính sách truy nhập bên trong bộ giám sát. Giám sát tham chiếu bao gồm 3 phần: *Giao tiếp* xác định vị trí mà mô-đun xác thực được gọi; *Mô-đun xác thực* xác định các truy vấn chính xác cần được gửi tới kho chính sách; *Kho chính sách* trả lời các truy vấn dựa trên hệ thống bảo vệ mà nó duy trì. Các bộ phận của bộ giám sát tham chiếu như trong hình dưới đây (Hình 1-6).

Giao tiếp xác định nơi mà các truy vấn/yêu cầu hệ thống bảo vệ được thực hiện tới bộ giám sát. Về cơ bản tất cả các thao tác nhạy cảm về an ninh được xác thực bởi cơ chế thực thi truy nhập. Các thao tác nhạy cảm là các thao tác thực hiện trên một đối tượng cụ thể (file, socket...) mà các thao tác này có thể xâm phạm các yêu cầu an ninh của hệ thống.



Hình 1-6. Tương tác giữa tiến trình và bộ giám sát tham chiếu

Mô-đun xác thực là bộ phận cốt lõi của bộ phận giám sát tham chiếu. Bộ phận này nhận các tham số đầu vào từ giao tiếp như định danh tiến trình, tham chiếu đối tượng, tên lời gọi hệ thống ... và thực hiện truy vấn kho chính sách để trả lời về tính hợp lệ của truy vấn từ giao tiếp. Thách thức của mô-đun này là ánh xạ các định danh của tiến trình thành các nhãn chủ thể, các tham chiếu đối tượng thành các nhãn đối tượng và hoạt động cụ thể được chấp thuận. Ví dụ như với yêu cầu mở file *open*. Mô-đun này cần có nhãn chủ thể sinh yêu cầu, nhãn của đối tượng thư mục và trạng thái bảo vệ của yêu cầu (đọc hay ghi). Trong một vài trường hợp mô-đun xác thực có thể thực thi các yêu cầu phụ tới kho chính sách về việc dán nhãn như trong tình huống tạo mới đối tượng (như file) hay di chuyển các nhãn.

Kho chính sách chính là cơ sở dữ liệu về trạng thái bảo vệ, các nhãn trạng thái và trạng thái dịch chuyển. Các câu truy vấn có cấu trúc {nhãn chủ thể, nhãn đối tượng, tập thao tác} và trả về kết quả nhị phân (hợp lệ/không hợp lệ). Các truy vấn về việc dịch chuyển có dạng {nhãn chủ thể, nhãn đối tượng, tập thao tác, tài nguyên}. Các tài nguyên có thể là các thực thể hoạt động như bộ xử lý hay thụ động như file.

1.5.3 Xây dựng nhân an toàn

Nhân an toàn là cách tiếp cận dựa trên giám sát tham chiếu có kết hợp phân cứng và phần mềm để đảm bảo thực thi các chính sách an toàn của hệ thống. Giám sát tham chiếu đảm bảo việc giám sát mỗi truy nhập từ các chủ thể khác nhau của hệ thống tới từng tài nguyên/đối tượng. Mục tiêu chính của hầu hết các nhân an toàn là kiểm chứng việc triển khai ở mức độ mã nguồn thỏa mãn các yêu cầu của nhân an toàn. Việc này dẫn đến ứng dụng các phương pháp chính tắc hay bán chính tắc để kiểm chứng.

Cơ sở của nhân an toàn, về mặt lý thuyết, là trong hệ điều hành lớn một phần rất nhỏ chịu trách nhiệm về an toàn. Bằng cách cấu trúc lại hệ thống sao cho toàn bộ phần mềm

liên quan đến an toàn được tách ra thành phần nhân tin cậy của hệ điều hành thì hệ điều hành hầu như không chịu trách nhiệm việc thực thi an toàn. Nói cách khác, phần nhân an toàn khi này sẽ chịu trách nhiệm giám sát và thực thi các chính sách an toàn lên các hoạt động của hệ điều hành cũng như người dùng. Phần nhân phải được bảo vệ một cách thích đáng (chống xâm nhập) và không thể bỏ qua các kiểm tra truy nhập của nhân. Phần nhân cần phải nhỏ nhất có thể được để có thể xác minh tính đúng đắn của nó một cách dễ dàng.

Trong mọi khía cạnh, nhân an toàn giống hệ điều hành sơ khai. Nhân an toàn thực hiện các dịch vụ phục vụ hệ điều hành cũng như hệ điều hành thực thi các dịch vụ phục vụ các ứng dụng. Và ngay khi hệ điều hành thiết lập các hạn chế lên ứng dụng, nhân an toàn đặt ra các hạn chế với hệ điều hành. Trong khi hệ điều hành không đóng vai trò gì trong việc thực thi các chính sách an toàn được triển khai bởi nhân, hệ điều hành cần giữ cho hệ thống hoạt động và ngăn chặn việc từ chối phục vụ do ứng dụng lỗi hay có mục đích xấu. Không lỗi nào trong ứng dụng cũng như trong hệ điều hành xâm phạm đến chính sách an toàn của nhân.

1.6 Câu hỏi ôn tập

- 1) Các yêu cầu cơ bản về an toàn đối với hệ điều hành?
- 2) Khái niệm về mục tiêu an toàn của hệ điều hành?
- 3) Khái niệm về mô hình tin cậy?
- 4) Khái niệm về mô hình đe dọa?
- 5) Khái niệm về hệ thống bảo vệ
- 6) Trình bày về ma trận truy nhập. Cho ví dụ?
- 7) Trình bày về hệ thống bảo vệ bắt buộc. Cho ví dụ?
- 8) Nêu các chức năng cơ bản của bộ giám sát tham chiếu?
- 9) Các khái niệm cơ bản với nhân an toàn?
- 10) Giải thích các thuộc tính của bộ giám sát truy nhập?
- 11) Nêu và giải thích các nguyên tắc của kiến trúc an toàn?
- 12) Nêu khái niệm về tính toán tin cậy?
- 13) Các yêu cầu với nền tảng tính toán tin cậy?
- 14) Trình bày các chức năng cơ bản của mô-đun hạ tầng tin cậy TPM?

CHƯƠNG 2. CÁC CƠ CHẾ AN TOÀN PHẦN CỨNG

Để hệ điều hành hoạt động ổn định và hiệu quả, hệ điều hành cần phân biệt được các hoạt động của riêng bản thân và các hoạt động của chương trình người dùng. Việc này phức tạp do bản thân hệ điều hành cũng là một chương trình. Hệ điều hành phải theo dõi toàn bộ các hoạt động và đảm bảo các hoạt động này không vi phạm chính sách an toàn. Như vậy, hệ điều hành sử dụng một số cơ chế bảo vệ với sự hỗ trợ từ phần cứng để thực thi các cơ chế bảo vệ này một cách hiệu quả. Nhiều cơ chế an ninh từng được xây dựng bằng phần mềm thì nay được phát triển bằng phần cứng. Một số tính năng vẫn nằm trong phần mềm do độ phức tạp của các tính năng này hay do người thiết kế không muốn lệ thuộc vào các triển khai cụ thể. Thực sự, chúng ta không cần phần cứng tinh vi để xây dựng hệ điều hành an toàn. Các tính năng phần cứng được ưa thích hơn phần mềm là vì:

- Các tính năng an toàn này được chứng tỏ tin cậy hơn và được triển khai một cách đúng đắn. Điều này đúng chỉ là vì các chức năng thực hiện tại phần cứng đơn giản hơn và ít bị lỗi ngẫu nhiên so với phần mềm. Điều quan trọng là phần cứng sẽ không bị tác động bởi phần mềm khác.
- Đặt các chức năng an ninh vào phần cứng tạo nên kiến trúc trong sáng hơn.
- Phần cứng cho phép hiệu năng cao hơn, thực thi nhanh hơn so với phần mềm.

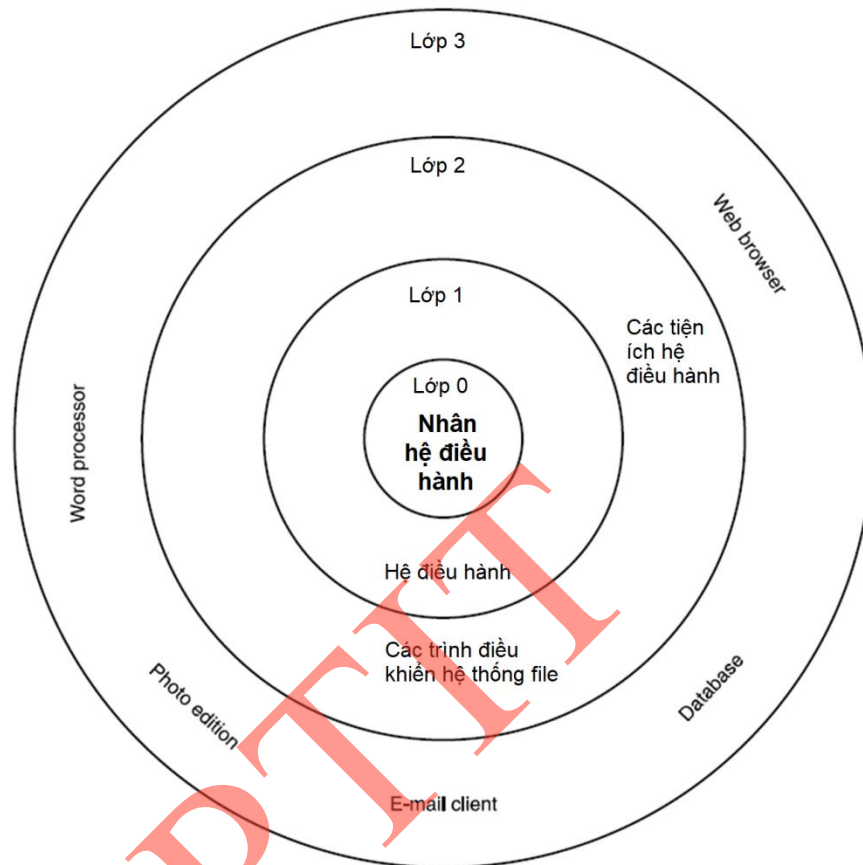
Phần dưới đây giới thiệu các chức năng cơ bản cần thiết từ phần cứng để hỗ trợ cho hệ điều hành trong các vấn đề về quản lý tiến trình, bộ nhớ và vào/ra.

2.1 Hỗ trợ các tiến trình

Một yêu cầu cơ bản của hệ điều hành an toàn là cách ly (chương trình) người dùng với nhau trong khi chấp nhận việc trao đổi thông tin qua các kênh được kiểm soát. Với các hệ điều hành hiện nay, các chương trình người dùng chạy song song với nhau nên việc chuyển đổi ngữ cảnh của các chương trình cần được thực hiện một cách nhanh chóng và hiệu quả. Phần cứng giúp làm đơn giản hóa việc này thông qua cơ chế “khởi động” lại cách chương trình bị dừng bằng cách lưu lại trạng thái của các tiến trình (chương trình đang chạy) và khôi phục đồng thời các thanh ghi mà chương trình sử dụng. Tuy nhiên, các bộ xử lý thế hệ đầu yêu cầu chương trình hệ thống lưu và khởi tạo từng thanh ghi một.

Mặt khác các bộ xử lý hỗ trợ việc cung cấp các không gian tách biệt để chạy các chương trình với các yêu cầu (đặc quyền) khác nhau. Các không gian này thường được biểu diễn như là chế độ hệ thống (đặc quyền) và người dùng (thông thường). Không gian hệ thống có được truy nhập không giới hạn tới các tài nguyên của hệ thống máy tính như toàn bộ không gian nhớ, các câu lệnh. Trong khi đó, không gian người dùng bị hạn chế

truy nhập tới bộ nhớ và tập hạn chế các câu lệnh. Một cách tổng quát, hệ thống phân cấp các không gian thực thi thành các lớp bảo vệ (*protection rings*). Các lớp đặt ra các ranh giới chặt chẽ và các mô tả những việc mà các chương trình (tiền trình) hoạt động trong từng lớp như những tài nguyên được truy nhập và những thao tác được phép thực hiện.



Hình 2-1. Các lớp bảo vệ tiêu biểu

Các chương trình nằm ở các lớp bên trong có nhiều đặc quyền hơn là nằm ở lớp ngoài. Nói cách khác, lớp có số thứ tự thấp hơn sẽ có nhiều đặc quyền hơn lớp có số lớn hơn. Số lượng các lớp tùy thuộc vào mục đích và nhu cầu cụ thể của hệ điều hành. Về cơ bản, các thành phần của hệ điều hành hoạt động tại lớp mà cung cấp các truy nhập tới vị trí bộ nhớ, thiết bị ngoại vi, trình điều khiển hệ thống và các tham số cấu hình nhạy cảm. Chính vì sử dụng các tài nguyên quan trọng nên đây là lớp được bảo vệ chặt chẽ nhất.

Các chương trình người dùng chịu hạn chế truy nhập đến bộ nhớ và các thiết bị phần cứng và chịu giám sát của hệ điều hành thông qua các chức năng của hệ điều hành hay lời gọi hệ thống. Nếu người dùng cố yêu cầu CPU thực hiện các lệnh vượt quá quyền hạn thì CPU xử lý những yêu cầu này như là lỗi hoặc cố gắng khóa chương trình lại.

Các lớp tiêu biểu

- Lớp 0 (*Ring 0*): Nhân hệ điều hành
- Lớp 1 (*Ring 1*): Phần còn lại của hệ điều hành
- Lớp 2 (*Ring 2*): Các trình điều khiển vào/ra và tiện ích

- Lớp 3(Ring 3): chương trình ứng dụng

Thực tế, các lớp bảo vệ được triển khai bằng cách kết hợp giữa phần cứng và hệ điều hành. Phần cứng (CPU) được cấu hình để hoạt động với một số lớp nhất định và hệ điều hành được xây dựng sao cho cùng hoạt động ở các lớp này. Các lớp bảo vệ hình thành nên các rào cản giữa chủ thể và đối tượng, và thực thi việc giám sát truy nhập khi các chủ thể thực hiện việc truy nhập tới các đối tượng:

- Mỗi đối tượng và chủ thể được gán một số thể hiện cấp độ của lớp bảo vệ
- Chủ thể có cấp độ thấp thì không thể truy nhập trực tiếp đối tượng có cấp độ cao hơn. Trong trường hợp cần thiết thì chủ thể có thể yêu cầu thông qua lời gọi hệ thống. Hệ điều hành sẽ thực hiện việc kiểm soát và hoàn tất truy nhập.

Việc thay đổi không gian thực hiện của chương trình chỉ được thực hiện thông qua lời gọi hàm call tới các mục được phép hợp lệ cho trước. Các hệ thống triển khai cơ chế gọi hàm như vậy dưới dạng các bẫy tới các con trỏ hay vị trí xác định trước trong không gian nhớ hệ thống. Với kiến trúc lớp, việc thay đổi lớp (như R1, R2) chỉ được hoàn tất thông qua câu lệnh call tới vị trí xác định trước trong phần nhớ đặc biệt gọi là cổng (gate) mà chúng được gán làm điểm khởi đầu cho lớp bên trong. Việc sử dụng cổng để ngăn chặn các chương trình thực hiện lời gọi hàm vào lớp trong và được thực hiện tại bất kỳ vị trí nhớ nào.

R1	R2	R3	W	R	E	RING	GATE
----	----	----	---	---	---	------	------

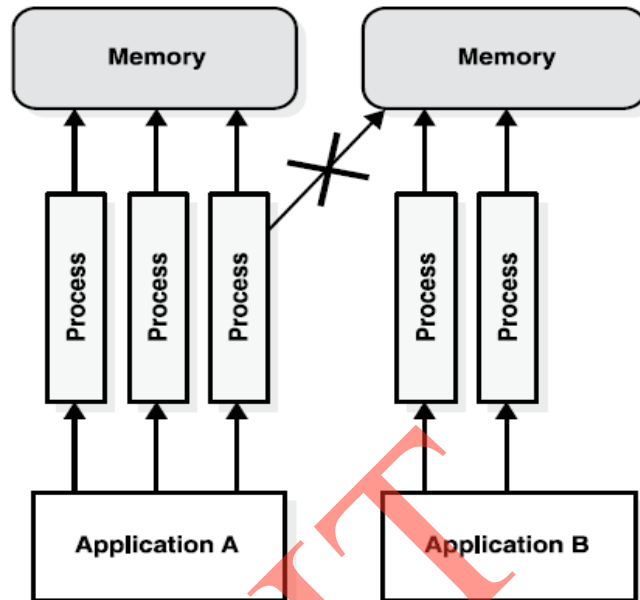
Hình 2-2. Cấu trúc mô tả phần nhớ cổng

Vị trí được chấp nhận trong phần cổng có thể được xác định bằng cách bổ sung thêm các trường trong mô tả cổng bao gồm mức truy nhập của lớp (ring bracket), trong đó R1 mức ghi, R2 mức đọc và R3 mức thực thi ví dụ R1=3 nghĩa là đoạn này có thể ghi với lớp từ 0 đến 3, và chế độ truy nhập W ghi, R đọc, và E thực thi của mỗi đoạn nhớ cho từng lớp. Tuy nhiên, có thể hạn chế đầu vào tại vị trí khởi đầu (bằng 0) của phần nhớ cổng là đủ. Số thứ tự lớp hiện thời sẽ chỉ thay đổi khi có phần nhớ cổng và câu lệnh call được kích hoạt.

2.2 Bảo vệ bộ nhớ

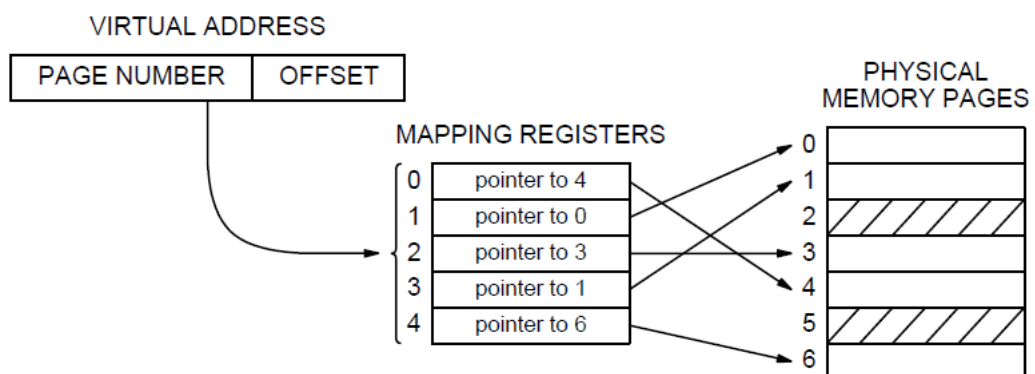
Một trong những yêu cầu phần cứng cơ bản nhất với hệ điều hành an toàn là cơ chế bảo vệ bộ nhớ. Trong hệ điều hành hiện đại, các chương trình của người dùng cần được cách ly về không gian nhớ với nhau và với các chương trình của người dùng hệ thống khác. Cơ chế bộ nhớ ảo được nhiều hệ thống hỗ trợ cho phép thay đổi không gian nhớ vật lý gán cho không gian nhớ mà chương trình có thể được sử dụng. Quá trình này hoàn toàn trong suốt với chương trình người dùng. Các chương trình thay vì truy nhập trực tiếp bộ nhớ vật lý thì thông qua các bảng chỉ số và con trỏ mô tả phần không gian nhớ lô-

gíc của chương trình. Chỉ có hệ điều hành mới truy nhập trực tiếp bộ nhớ nhờ các lệnh sử dụng đặc quyền. Như đã nêu trong phần trước, đặc quyền của các câu lệnh này được bộ xử lý kiểm tra trong quá trình thực thi bằng cách so sánh mức độ đặc quyền của câu lệnh với không gian nhớ được yêu cầu. Việc này giúp ngăn chặn các truy nhập của các chương trình người dùng nhằm lấy các thông tin về bộ nhớ vật lý của hệ thống.



Hình 2-3. Xung đột bộ nhớ chương trình người dùng

Trong các hệ thống đầu tiên, không gian nhớ của chương trình được xác định thông qua con trỏ cơ sở, cho biết vị trí bắt đầu, và con trỏ giới hạn, xác định vị trí kết thúc. Như vậy, chương trình người dùng không thể vượt ra ngoài không gian được cấp cho nó trhhhh tình huống xung đột như trong hình Hình 2-3. Để tăng tính hiệu quả trong việc quản lý, các biện pháp cấp phát theo khối nhớ (còn gọi là trang) với kích cỡ hợp lý thường được sử dụng như trong hình dưới đây thể hiện. Các con trỏ trong các thanh ghi cho biết vị trí bắt đầu của các trang trên bộ nhớ vật lý tùy thuộc theo tình hình hoạt động của hệ điều hành. Các trang nhớ của chương trình không nhất thiết phải liên tục. Hình 2-4 biểu diễn cách thức xác định địa chỉ của bộ nhớ vật lý từ địa chỉ của bộ nhớ ảo.

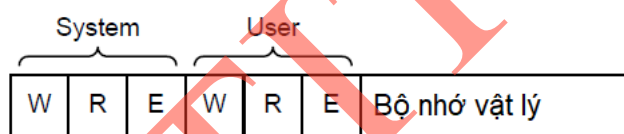


Hình 2-5. Ánh xạ từ bộ nhớ ảo tới bộ nhớ vật lý

Khi hệ thống phân cấp các chương trình theo các lớp bảo vệ (chế độ hệ thống và chế độ người dùng) thì các chương trình người dùng không được phép đọc ghi tùy tiện vào không gian nhớ của hệ thống. Mặt khác, khi ở chế độ hệ thống chương trình được phép truy nhập toàn bộ không gian nhớ vật lý của máy tính. Việc chuyển đổi không gian thực hiện chương trình được thực hiện nhờ câu lệnh đặc biệt. Để tăng độ linh hoạt, hệ điều hành có thể chỉ định chính xác các phần (trang) của bộ nhớ được phép truy nhập tùy theo ngữ cảnh thực hiện chương trình.

Trước khi có được việc quản lý bộ nhớ một cách trong suốt, quyết định truy nhập được dựa trên định danh của các trang vật lý. Mỗi trang được gán nhãn như khóa, các bit truy nhập chỉ định thao tác đọc/ghi. Mỗi chương trình người dùng khi chạy được gán một khóa. Phần cứng, hay bộ xử lý, sẽ tiến hành kiểm tra khóa mỗi khi có tham chiếu bộ nhớ. Truy nhập được phép chỉ khi khóa truy nhập trùng với khóa mô tả đúng thao tác mà người dùng mong muốn.

Với cơ chế chuyển đổi địa chỉ dựa trên các thẻ mô tả (descriptor), mỗi tiến trình có tập riêng các thẻ mô tả, chế độ truy nhập của các tiến trình tới phần (trang) nhớ được xác định trong các mô tả như hình dưới đây với W(Ghi), R(Đọc), E (Chạy) là các bit cho biết tiến trình có khả năng truy nhập tới vùng nhớ như thế nào.



Hình 2-6. Mô tả các chế độ truy nhập bộ nhớ của User và System

Do các mô tả được nạp trong quá trình dịch địa chỉ nhớ nên cơ chế kiểm soát dựa trên các mô tả này giảm thiểu các chi phí trong quá trình chuyển ngữ cảnh hay hoán đổi của tiến trình.

Như vậy, các cơ chế phần cứng giúp bảo vệ các thông tin quan trọng với việc quản lý bộ nhớ như cấu trúc chuyển đổi địa chỉ ảo thành địa chỉ vật lý. Những nỗ lực truy nhập thông tin bộ nhớ từ chương trình người dùng sẽ bị ngăn chặn từ mức phần cứng.

2.3 Kiểm soát thao tác vào/ra

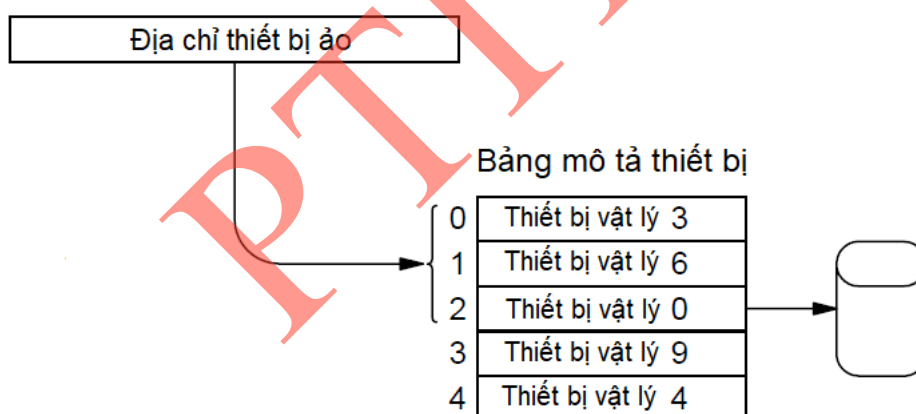
Trong các chức năng của hệ điều hành tiêu biểu, các thao tác vào/ra thường phức tạp nhất. Trong khi phần cứng hỗ trợ các tiến trình, quản lý bộ nhớ được hướng tới việc làm thuận tiện cho người lập trình thì phần cứng hỗ trợ vào/ra có vẻ như không hướng tới việc triển khai hệ thống vào/ra một cách dễ hiểu. Thay vào đó, mục tiêu của thiết kế vào/ra là hiệu năng và chi phí chứ không phải là an toàn. Nói chung, vào/ra là các thao tác đặc quyền được thực hiện chỉ bởi hệ điều hành. Hệ điều hành cung cấp các thao tác mức cao và người dùng không cần thiết kiểm soát các chi tiết của thao tác vào/ra. Hệ điều hành sẽ đơn giản hơn rất nhiều nếu như nó không phải trung gian kiểm soát các thao tác này. Trên nguyên tắc, hệ điều hành không tham gia vào việc kiểm soát truy nhập tới

các thiết bị do người dùng sở hữu. Với hỗ trợ phù hợp từ phần cứng, việc kiểm soát các thiết bị này được chuyển cho các chương trình ứng dụng bên ngoài hệ điều hành.

Phần cứng hỗ trợ cho quản lý bộ nhớ chủ yếu tập trung vào các truy nhập từ bộ xử lý tới bộ nhớ. Khi kết hợp với thao tác vào/ra cần có thêm một số kênh thông tin khác như: thiết bị tới bộ nhớ, thiết bị tới bộ xử lý. Việc kiểm soát truy nhập tới các thiết bị này cần phải dựa trên định danh của chủ thể (tiền trình) đại diện cho thiết bị được sử dụng và đối tượng (phần bộ nhớ) được sử dụng. Từ góc độ kiểm soát truy nhập, phần cứng có thể hỗ trợ vào/ra theo 4 cách từ đơn giản đến phức tạp:

- Lập trình
- Không ánh xạ (unmapped)
- Ánh xạ trước (premapped)
- Ánh xạ đầy đủ

Vào/ra được lập trình là cơ chế đồng bộ theo nghĩa bộ xử lý kiểm soát trực tiếp từng đơn vị dữ liệu được trao đổi tới thiết bị vào/ra. Như vậy vấn đề an ninh duy nhất là tiền trình yêu cầu vào/ra truy nhập tới được thiết bị. Cách trực quan nhất để xử lý vấn đề này là sử dụng bảng mô tả thiết bị (device descriptor table) cho phép ánh xạ tên thiết bị tới thiết bị vật lý cụ thể và kèm theo là các mô tả kiểm soát giống như kiểm soát bộ nhớ như trong hình dưới đây



Hình 2-7. Ánh xạ thiết bị ảo tới thiết bị vật lý

Vào/ra không ánh xạ thường không cho phép chương trình người dùng làm việc trực tiếp với các địa chỉ vật lý mà chỉ được kích hoạt từ hệ điều hành. Hệ điều hành sẽ chuyển các địa chỉ bộ đệm dùng cho vào/ra từ chương trình người dùng thành các địa chỉ vật lý. Mặc dầu phần cứng hỗ trợ việc chuyển đổi tên thiết bị ảo giống như vào/ra lập trình song việc này không giải phóng nhiệm vụ hệ điều hành phải xác thực và thực hiện các thao tác vào/ra.

Vào/ra ánh xạ trước hay ảo cho phép phần mềm xác định địa chỉ bộ đệm ảo. Khi các câu lệnh vào/ra được thực hiện, bộ xử lý sẽ chuyển các địa chỉ ảo này thành địa chỉ vật lý sử dụng bảng mô tả thiết bị và ánh xạ các thanh ghi của tiền trình hiện thời; và bộ xử lý chuyển địa chỉ vật lý thu được tới thiết bị. Trong quá trình chuyển, bộ xử lý kiểm tra liệu

tiến trình có quyền truy nhập hợp lệ tới vị trí đọc ghi. Từ phía thiết bị, các địa chỉ vào/ra là thật (vật lý) nhưng từ góc độ chương trình các địa chỉ là ảo và việc kiểm soát truy nhập được thực thi nhờ phần cứng. Các thiết bị phải được tin cậy để truy nhập tới vị trí mong muốn trong bộ nhớ.

Ngay cả khi phần cứng không hỗ trợ vào/ra, chương trình người dùng cũng không thể sinh ra các câu lệnh vào/ra mà không có sự can thiệp của hệ điều hành. Cần có cơ chế ngăn chặn hệ điều hành khỏi việc gán lại một cách vô tình (như việc hoán đổi bộ nhớ) các trang nhớ bị ảnh hưởng trong khi vào/ra do người dùng khởi xướng đang xảy ra. Các cơ chế ảo hóa giải phóng hệ điều hành khỏi việc thực hiện chuyển đổi địa chỉ và kiểm soát truy nhập song hệ điều hành vẫn phải chịu trách nhiệm quản lý và theo dõi các thao tác vào/ra.

Với vào/ra ánh xạ trước yêu cầu các thiết bị vào/ra tin cậy và các tham chiếu trở tới địa chỉ vật lý định trước cũng như tuân thủ các hạn chế vào/ra mà bộ xử lý giám sát. Tuy nhiên, có những trường hợp thiết bị vào/ra phức tạp như sử dụng vi chương trình với phần firmware được nạp xuống. Với các hệ thống cần an ninh cao, việc gán độ tin cậy cao cho phần cứng và phần firmware mà đôi khi không kiểm soát được lại không phù hợp. Đặc biệt khi bản thân các thiết bị phần cứng lại nằm ngoài phạm vi đảm bảo an ninh như các thiết bị ở xa.

Dạng vào/ra an toàn hơn gồm phần cứng thực hiện việc chuyển địa chỉ từ ảo-thực (vật lý) với mỗi tham chiếu bộ nhớ được thực hiện bởi thiết bị. Thiết bị hoạt động như đối tượng không tin cậy (có thể chứa mã trojan) sử dụng các địa chỉ ảo khi đọc ghi thông tin trong bộ nhớ; phần cứng mà thực hiện việc chuyển địa chỉ nằm trong vùng được bảo vệ thực hiện việc ánh xạ và kiểm tra truy nhập. Phần cứng sử dụng cùng các mô tả bộ nhớ mà thuộc về các tiến trình khởi tạo vào/ra. Nhờ việc chuyển địa chỉ và kiểm tra được thực hiện trên từ mức đơn vị dữ liệu nên sẽ không gặp phải vấn đề an ninh khi hệ điều hành phân phối lại bộ nhớ trong quá trình vào/ra. Do việc vào/ra là dị bộ nên địa chỉ ảo của thiết bị vào/ra không nhất thiết phải gắn với không gian nhớ của chương trình đang chạy.

2.4 Ảo hóa

Ảo hóa giúp cho việc tận dụng và chia sẻ tài nguyên máy tính được thuận tiện và dễ dàng hơn đặc biệt khi năng lực xử lý của hệ thống máy tính được nâng cao. Phần cứng hỗ trợ ảo hóa làm cho hiệu năng của các phần mềm ảo hóa được cải thiện và hiệu năng được người dùng chấp nhận hơn. Các yêu cầu cơ bản với máy tính cho phép ảo hóa bao gồm:

- Tính hiệu quả: Tất cả các câu lệnh bình thường được thực hiện trực tiếp bởi phần cứng mà không có sự can thiệp nào của các chương trình giám sát.
- Kiểm soát tài nguyên: Không cho phép bất kỳ chương trình nào ảnh hưởng tới các tài nguyên hệ thống như bộ nhớ và tính sẵn dùng của nó. Bộ cấp phát được gọi bất cứ khi nào chương trình cần.

- **Bình đẳng:** Bất kỳ chương trình nào đang chạy với sự hiện diện của chương trình kiểm soát cũng được thực hiện mà không khác gì trường hợp không có chương trình giám sát này với truy nhập không hạn chế các câu lệnh đặc quyền mà người lập trình dự định.

Ảo hóa cũng giúp cho việc đảm bảo an toàn cho chương trình một cách linh hoạt hơn do các chương trình người dùng hoạt động trong các không gian cách ly với nhau. Tuy nhiên, có vấn đề khó khăn khi thiết kế máy tính có khả năng “bẫy” các câu lệnh có đặc quyền. Các câu lệnh có đặc quyền nhất được thực hiện ở lớp 0 và dành riêng cho hệ điều hành. Các hệ thống ảo chạy trên nền hệ điều hành không thể truy nhập đến lớp 0 này một cách trực tiếp mà phải thông qua bước chuyển không gian thực hiện (thay đổi đặc quyền). Ảo hóa một phần (paravirtualisation) giúp làm giảm chi phí cho việc chuyển đổi này bằng cách sử dụng bộ thư viện API mà phần mềm ảo có thể truy nhập các thao tác đặc quyền.

Ảo hóa phần cứng làm giảm sự can thiệp của hệ thống chủ trong việc xử lý các vấn đề quản lý việc chuyển không gian địa chỉ và đặc quyền. Intel với VT-i và AMD với AMD-V là các công nghệ ảo hóa giúp đơn giản hóa hệ thống chủ và đảm bảo hiệu năng gần như thật với hệ thống được ảo hóa. Hỗ trợ từ phần cứng cho phép chuyển đổi nhanh chóng giữa hệ thống ảo hóa và bộ phận giám sát (hệ thống chủ) và cấp các thiết bị vào/ra một cách an toàn cho các hệ thống ảo hóa.

2.5 Kết luận

Chương này trình bày cơ chế bảo vệ và cách ly các tiến trình thông qua việc sử dụng cơ chế lớp bảo vệ với sự hỗ trợ từ phần cứng. Việc phân chia các lệnh hay các thao tác theo các nhóm đặc quyền cho phép hạn chế việc sử dụng các câu lệnh của các chương trình người dùng cũng như các chương trình ở mức hệ điều hành trong việc sử dụng các tài nguyên của hệ thống. Qua đó bảo vệ các tài nguyên này khỏi các truy nhập không được phép.

Sử dụng nguyên tắc tương tự với vấn đề quản lý bộ nhớ và các thao tác vào/ra. Các tiến trình bị hạn chế truy nhập trực tiếp tới không gian nhớ vật lý thông qua các kỹ thuật như phân trang và bộ nhớ ảo. Các thông tin trực tiếp về việc cấp phát vị trí nhớ cũng như việc truy nhập vào các thẻ thông tin quản lý việc cấp phát được lưu trữ trong không gian nhớ được bảo vệ và được kiểm soát thông qua cơ chế đặc quyền. Như vậy, các tiến trình người dùng sẽ bị che dấu các thông tin vật lý và việc truy nhập chỉ dành cho các tiến trình của hệ điều hành. Điều này giúp giảm thiểu rủi ro và xung đột giữa các tiến trình cũng như việc rò rỉ thông tin bởi các tiến trình có độ tin cậy thấp. Ảo hóa là bước tiến quan trọng trong việc quản lý và phân chia các tài nguyên dùng chung của hệ thống phần cứng. Việc triển khai thành công ảo hóa giúp giảm thiểu các rủi ro về an toàn thông tin.

Các cơ chế phần cứng cung cấp công cụ tin cậy cho việc triển khai an toàn và thẩm tra được việc thoả mãn các yêu cầu an toàn của hệ thống. Việc triển khai ở mức phần

cứng giúp hạn chế tối đa việc can thiệp và sửa đổi trái phép vào quá trình kiểm soát do cách cơ chế này được thực thi từ mức phần cứng.

2.6 Câu hỏi ôn tập

- 1) Nêu khái niệm về lớp bảo vệ của CPU?
- 2) Giải thích việc thực hiện cơ chế lớp bảo vệ trong tập lệnh x86?
- 3) Cách thức bảo vệ bộ nhớ từ mức phần cứng?
- 4) Nêu các kỹ thuật đảm bảo an toàn cho các thiết bị vào/ra từ mức phần cứng?
- 5) Các yêu cầu cơ bản với máy ảo?

PTIT